BẢN DỊCH TIẾNG VIỆT ĐẦY ĐỦ

CEH v13 - Module 02
Footprinting và Reconnaissance

Bản dịch theo từng trang PDF gốc - 158 trang

Ghi chú chung về bản dịch:

- Dịch toàn bộ nội dung văn bản của tài liệu người dùng cung cấp theo từng trang PDF gốc.
- Tên sản phẩm, tên công cụ, tên miền, URL, địa chỉ IP, tham số dòng lệnh, câu lệnh, mã nguồn, tên chứng chỉ và các từ viết tắt kỹ thuật được giữ nguyên khi cần để tránh làm sai nghĩa hoặc làm lệnh không còn sử dụng được.
- Các chuỗi tiếng Anh nằm trong mã nguồn/câu lệnh được giữ nguyên khi chúng là một phần của ví dụ kỹ thuật; phần giải thích bên ngoài mã được dịch đầy đủ.
- Dấu mờ “hide01.ir” xuất hiện xuyên suốt tài liệu, được giữ nguyên tên và không dịch.
- Đầu trang lặp lại: “Ethical Hacking and Countermeasures - Footprinting and Reconnaissance” = “Ethical Hacking và các biện pháp đối phó - Footprinting và Reconnaissance”. “Exam 312-50 Certified Ethical Hacker” = “Kỳ thi 312-50 Certified Ethical Hacker”.
- Chân trang lặp lại: “Ethical Hacking and Countermeasures Copyright © by EC-Council. All Rights Reserved. Reproduction is Strictly Prohibited.” = “Ethical Hacking và các biện pháp đối phó, bản quyền © thuộc EC-Council. Bảo lưu mọi quyền. Nghiêm cấm sao chép.”

Trang 1 (theo PDF gốc)

Mô-đun 02

FOOTPRINTING VÀ RECONNAISSANCE

EC-Council - Giáo trình chính thức

CEH v13 - Certified Ethical Hacker

Trang 2 (theo PDF gốc)

Trang này được cố ý để trống.

Trang 3 (theo PDF gốc)

MỤC TIÊU HỌC TẬP

01. Giải thích các khái niệm Footprinting
02. Minh họa Footprinting thông qua công cụ tìm kiếm
03. Minh họa Footprinting thông qua các dịch vụ nghiên cứu Internet
04. Minh họa Footprinting thông qua các trang mạng xã hội
05. Sử dụng các kỹ thuật khác nhau cho Whois Footprinting
06. Sử dụng các kỹ thuật khác nhau cho DNS Footprinting
07. Sử dụng các kỹ thuật khác nhau cho Network và Email Footprinting
08. Minh họa Footprinting thông qua Social Engineering
09. Tự động hóa các tác vụ Footprinting bằng công cụ nâng cao và AI
10. Giải thích các biện pháp đối phó Footprinting

Mục tiêu học tập

Footprinting là bước đầu tiên trong việc đánh giá tư thế bảo mật của hạ tầng CNTT của một tổ chức mục tiêu. Thông qua footprinting và reconnaissance, người ta có thể thu thập lượng thông tin tối đa về một máy tính hoặc một mạng, cũng như về bất kỳ thiết bị nào kết nối với mạng đó. Nói cách khác, footprinting cung cấp một bản thiết kế hồ sơ bảo mật của tổ chức và nên được thực hiện theo một cách có phương pháp.

Mô-đun này bắt đầu bằng phần giới thiệu về các khái niệm footprinting và cung cấp cái nhìn sâu về phương pháp footprinting. Sau đó, mô-đun kết thúc bằng phần tổng quan về các công cụ footprinting và biện pháp đối phó.

Khi hoàn thành mô-đun này, bạn sẽ có thể:

- Mô tả các khái niệm footprinting.
- Thực hiện footprinting thông qua các công cụ tìm kiếm và sử dụng các kỹ thuật Google hacking nâng cao.
- Thực hiện footprinting thông qua các dịch vụ nghiên cứu Internet và các trang mạng xã hội.
- Thực hiện Whois, DNS, network và email footprinting.
- Thực hiện footprinting thông qua social engineering.
- Sử dụng các công cụ footprinting khác nhau.
- Áp dụng các thực hành tốt nhất về footprinting.

Trang 4 (theo PDF gốc)

Mục tiêu 01: Giải thích các khái niệm Footprinting

KHÁI NIỆM FOOTPRINTING

Bước này đóng vai trò là giai đoạn chuẩn bị cho kẻ tấn công, người cần thu thập càng nhiều thông tin càng tốt để có thể dễ dàng tìm ra cách xâm nhập vào mạng mục tiêu.

Phần này nhằm giúp bạn làm quen với footprinting, lý do tại sao nó cần thiết và các mục tiêu của nó.

Trang 5 (theo PDF gốc)

RECONNAISSANCE

Reconnaissance (còn gọi là footprinting) là giai đoạn chuẩn bị, trong đó kẻ tấn công tìm cách thu thập càng nhiều thông tin càng tốt về mục tiêu để đánh giá hoặc tiến hành một cuộc tấn công. Một khía cạnh thiết yếu của footprinting là xác định mức độ rủi ro gắn với tư thế bảo mật của tổ chức mục tiêu. Footprinting, bước đầu tiên trong ethical hacking, đề cập đến quá trình thu thập thông tin về một tổ chức mục tiêu để tạo một hồ sơ duy nhất về mạng và hệ thống của tổ chức đó.

Sau khi hoàn thành quá trình footprinting một cách có phương pháp, bạn sẽ có được “dấu chân” của tư thế bảo mật của tổ chức mục tiêu. Ở đây, thuật ngữ “blueprint” đề cập đến hồ sơ hệ thống duy nhất của tổ chức mục tiêu thu được từ footprinting.

Không có một phương pháp duy nhất cho footprinting, vì thông tin có thể được tạo ra theo nhiều cách. Tuy nhiên, hoạt động thường thực hiện như quét phạm vi mạng hoặc thu thập email về tổ chức mục tiêu trước khi bắt đầu giai đoạn hacking. Vì vậy, footprinting cần được thực hiện có tổ chức. Thông tin thu thập ở bước này giúp phát hiện các lỗ hổng trong mạng mục tiêu và xác định những cách khác nhau để khai thác các lỗ hổng đó.

Các loại Footprinting/Reconnaissance

Footprinting có thể được phân loại thành footprinting thụ động và chủ động.

Footprinting thụ động

Footprinting thụ động liên quan đến việc thu thập thông tin về mục tiêu mà không tương tác trực tiếp. Nó chủ yếu hữu ích khi các hoạt động thu thập thông tin không thể bị mục tiêu phát hiện. Thực hiện footprinting thụ động về mặt kỹ thuật khó hơn, vì lưu lượng chủ động không được gửi đến tổ chức mục tiêu từ máy chủ hoặc dịch vụ ẩn danh trên Internet.

Trang 6 (theo PDF gốc)

Trong footprinting thụ động, người ta chỉ thu thập thông tin lưu trữ và thông tin được lập chỉ mục về mục tiêu bằng công cụ tìm kiếm, trang mạng xã hội, v.v.

Footprinting thụ động bao gồm:

- Thu thập Open-source intelligence (OSINT).
- Cơ sở dữ liệu độc quyền và các dịch vụ trả phí.
- Chia sẻ thông tin trong các tổ chức hoặc nhóm ngành.

Footprinting chủ động

Footprinting chủ động liên quan đến việc thu thập thông tin về mục tiêu thông qua tương tác trực tiếp. Trong footprinting chủ động, mục tiêu có thể nhận biết quá trình thu thập thông tin khi chúng ta tương tác trực tiếp với mạng mục tiêu. Footprinting chủ động đòi hỏi nhiều sự chuẩn bị hơn so với footprinting thụ động, vì nó có thể để lại dấu vết tại tổ chức mục tiêu.

Footprinting chủ động bao gồm:

- Thẩm vấn DNS (DNS interrogation).
- Social engineering.
- Quét mạng/cổng.
- Liệt kê người dùng và dịch vụ.

Trang 7 (theo PDF gốc)

THÔNG TIN THU ĐƯỢC TRONG FOOTPRINTING

Các mục tiêu chính của footprinting là thu thập thông tin mạng, thông tin hệ thống và thông tin tổ chức của mục tiêu. Bằng cách thực hiện footprinting trên các mức mạng khác nhau, bạn có thể thu thập thông tin như các khối mạng, địa chỉ IP cụ thể, thông tin nhân viên, v.v. Những thông tin như vậy có thể giúp kẻ tấn công giành quyền truy cập vào dữ liệu nhạy cảm hoặc thực hiện nhiều cuộc tấn công vào mạng mục tiêu.

Thông tin tổ chức

Thông tin về một tổ chức có sẵn trên website của tổ chức đó. Ngoài ra, bạn có thể truy vấn tên miền của mục tiêu đối với cơ sở dữ liệu Whois và thu được thông tin có giá trị.

Thông tin thu thập bao gồm:

- Chi tiết nhân viên (tên nhân viên, địa chỉ liên hệ, chức danh và kinh nghiệm làm việc).
- Địa chỉ và số điện thoại/di động.
- Chi tiết thương hiệu và vị trí.
- Các bộ phận của tổ chức.
- Liên kết web đến các trang liên quan khác của công ty.
- Thông tin nền về tổ chức.
- Công nghệ web.
- Bài báo, thông cáo báo chí và tài liệu liên quan.
- Tài liệu pháp lý liên quan đến tổ chức.
- Bằng sáng chế và nhãn hiệu liên quan đến tổ chức.

Trang 8 (theo PDF gốc)

Kẻ tấn công có thể truy cập thông tin tổ chức và sử dụng thông tin đó để xác định nhân sự chủ chốt, rồi phát động các cuộc tấn công social engineering nhằm lấy dữ liệu nhạy cảm về thực thể.

Thông tin mạng

Bạn có thể thu thập thông tin mạng bằng cách thực hiện phân tích cơ sở dữ liệu Whois, tracerouting, v.v.

Thông tin thu thập gồm:

- Tên miền và tên miền phụ.
- Các khối mạng.
- Cấu trúc liên kết mạng, router tin cậy và tường lửa.
- Địa chỉ IP của các hệ thống có thể truy cập.
- Bản ghi Whois.
- Bản ghi DNS và thông tin liên quan.

Thông tin hệ thống

Bạn có thể thu thập thông tin hệ thống bằng cách thực hiện network footprinting, DNS footprinting, website footprinting, email footprinting, v.v.

Thông tin thu thập gồm:

- Hệ điều hành máy chủ web.
- Vị trí máy chủ web.
- Các địa chỉ email công khai có sẵn.
- Tên người dùng, mật khẩu, v.v.

MỤC TIÊU CỦA FOOTPRINTING

Để xây dựng chiến lược tấn công, kẻ tấn công phải thu thập thông tin về mạng của tổ chức mục tiêu. Sau đó, họ sử dụng thông tin đó để xác định cách dễ nhất nhằm xâm nhập vào vành đai an ninh của tổ chức. Như đã đề cập trước đó, quá trình footprinting giúp dễ dàng thu thập thông tin về tổ chức mục tiêu và đóng vai trò quan trọng trong quá trình hacking.

Footprinting cung cấp một sơ đồ về tư thế bảo mật, chẳng hạn như vị trí tường lửa, proxy và các giải pháp bảo mật khác. Kẻ tấn công có thể phân tích báo cáo footprinting để xác định các lỗ hổng trong tư thế bảo mật của tổ chức mục tiêu và xây dựng kế hoạch hacking tương ứng.

Bằng cách sử dụng kết hợp các công cụ và kỹ thuật, kẻ tấn công có thể lấy một thực thể không xác định (ví dụ: tổ chức XYZ) và thu hẹp nó thành một dải cụ thể gồm tên miền, khối mạng và địa chỉ IP riêng lẻ của các hệ thống kết nối trực tiếp với Internet, bên cạnh những chi tiết khác liên quan đến tư thế bảo mật của tổ chức.

Một footprint chi tiết cung cấp lượng thông tin tối đa về tổ chức mục tiêu, cho phép kẻ tấn công xác định các lỗ hổng trong hệ thống mục tiêu để chọn khai thác phù hợp. Kẻ tấn công có thể xây dựng cơ sở dữ liệu thông tin về tư thế bảo mật của tổ chức mục tiêu. Cơ sở dữ liệu như vậy có thể giúp xác định mắt xích yếu nhất trong vành đai bảo mật của tổ chức.

Trang 9 (theo PDF gốc)

CÁC MỐI ĐE DỌA TỪ FOOTPRINTING

Dưới đây là một số mối đe dọa tiềm ẩn do footprinting tạo ra:

- Social Engineering: Không sử dụng bất kỳ phương pháp xâm nhập nào, hacker trực tiếp hoặc gián tiếp thu thập thông tin thông qua thuyết phục và các phương tiện khác. Hacker thu thập thông tin quan trọng từ nhân viên không nhận thức được ý đồ của hacker.
- Tấn công hệ thống và mạng: Footprinting cho phép kẻ tấn công thực hiện các cuộc tấn công hệ thống và mạng. Do đó, kẻ tấn công có thể thu thập thông tin liên quan đến cấu hình hệ thống của tổ chức mục tiêu, hệ điều hành chạy trên máy, v.v. Sử dụng thông tin này, kẻ tấn công có thể tìm các lỗ hổng trong hệ thống mục tiêu rồi khai thác những lỗ hổng đó. Họ có thể kiểm soát một hệ thống hoặc toàn bộ mạng.
- Rò rỉ thông tin: Rò rỉ thông tin gây ra mối đe dọa cho bất kỳ tổ chức nào. Nếu thông tin nhạy cảm của một thực thể rơi vào tay kẻ tấn công, chúng có thể thực hiện một cuộc tấn công dựa trên thông tin hoặc, thay vào đó, sử dụng thông tin đó để tống tiền.
- Mất quyền riêng tư: Thông qua footprinting, hacker có thể truy cập các hệ thống và mạng của tổ chức và thậm chí nâng quyền lên cấp quản trị viên, dẫn đến mất quyền riêng tư đối với tổ chức nói chung và đối với người dùng cá nhân.
- Gián điệp doanh nghiệp: Gián điệp doanh nghiệp là mối đe dọa trung tâm đối với các tổ chức, vì đối thủ cạnh tranh thường cố gắng thu thập dữ liệu nhạy cảm thông qua footprinting. Qua cách tiếp cận này, đối thủ cạnh tranh có thể khởi động sản phẩm trên thị trường, thay đổi giá và nói chung làm suy yếu vị thế thị trường của tổ chức mục tiêu.
- Tổn thất kinh doanh: Footprinting có thể ảnh hưởng lớn đến các tổ chức như doanh nghiệp trực tuyến và các dịch vụ thương mại điện tử, cũng như ngân hàng và doanh nghiệp tài chính. Hàng tỷ đô la bị thất thoát mỗi năm do các cuộc tấn công độc hại của hacker.

Trang 10 (theo PDF gốc)

PHƯƠNG PHÁP FOOTPRINTING

Bây giờ bạn đã quen với các khái niệm footprinting và các mối đe dọa tiềm ẩn, chúng ta sẽ thảo luận về phương pháp footprinting. Phương pháp footprinting là một quy trình thu thập thông tin về một tổ chức mục tiêu từ tất cả các nguồn có sẵn. Nó bao gồm việc thu thập thông tin về tổ chức mục tiêu, chẳng hạn URL, vị trí, chi tiết cơ sở, số điện thoại, ID nhân viên và tên miền phụ, chi tiết liên hệ, và các thông tin khác; người tấn công thu thập thông tin từ các nguồn có thể truy cập công khai như công cụ tìm kiếm, trang mạng xã hội, cơ sở dữ liệu Whois, v.v. Sơ đồ trong tài liệu minh họa các kỹ thuật phổ biến được sử dụng để thu thập thông tin về tổ chức mục tiêu từ các nguồn khác nhau.

Các kỹ thuật footprinting chính được chia thành:

- Thụ động: Footprinting qua công cụ tìm kiếm; dịch vụ nghiên cứu Internet; mạng xã hội; Whois.
- Chủ động: DNS footprinting; network và email footprinting; social engineering; các công cụ/tác vụ tự động và AI.

Hình 2.1: Các kỹ thuật Footprinting.

Trang 11 (theo PDF gốc)

Mục tiêu 02: Minh họa Footprinting thông qua công cụ tìm kiếm

Reconnaissance thụ động

FOOTPRINTING THÔNG QUA CÔNG CỤ TÌM KIẾM

Công cụ tìm kiếm là một trong những nguồn thông tin quan trọng nhất về một tổ chức mục tiêu. Chúng đóng vai trò lớn trong việc trích xuất dữ liệu quan trọng về một mục tiêu từ Internet. Công cụ tìm kiếm sử dụng phần mềm tự động, tức crawler, để liên tục quét các website đang hoạt động và thêm kết quả truy xuất vào chỉ mục của công cụ tìm kiếm, vốn được lưu trong một cơ sở dữ liệu lớn. Khi người dùng nhập truy vấn vào thanh tìm kiếm của công cụ, nó trả về một danh sách các Trang Kết quả Công cụ Tìm kiếm (SERP). Các kết quả này bao gồm trang web, video, hình ảnh và nhiều loại nội dung khác được xếp hạng và hiển thị theo mức độ liên quan. Nhiều công cụ tìm kiếm có thể trích xuất thông tin tổ chức, chẳng hạn vị trí, nhân viên, địa chỉ email, trang đăng nhập, thông tin liên hệ, v.v. Từ các nguồn thông tin này, hacker có thể thực hiện social engineering và các kiểu tấn công hệ thống nâng cao khác.

Trang 12 (theo PDF gốc)

FOOTPRINTING BẰNG CÁC KỸ THUẬT GOOGLE HACKING NÂNG CAO

Một kết quả tìm kiếm Google có thể tiết lộ những thông tin mà bộ phận CNTT hoặc nhân viên của một tổ chức giả định là đã được giữ bí mật. Thông tin này giúp kẻ tấn công xác định các lỗ hổng trong các biện pháp kiểm soát bảo mật.

Ví dụ, hãy xem xét tổ chức Microsoft. Gõ Microsoft vào hộp Search của một công cụ tìm kiếm rồi nhấn Enter; thao tác này sẽ hiển thị kết quả có chứa thông tin về Microsoft. Duyệt các kết quả thường cung cấp những thông tin quan trọng như vị trí vật lý, địa chỉ liên hệ, dịch vụ cung cấp, số lượng nhân viên, v.v., có thể là nguồn có giá trị cho hoạt động hacking.

Ví dụ về các công cụ tìm kiếm lớn gồm Google, Bing, Yahoo, Ask, AOL, Baidu, Yandex, WolframAlpha và DuckDuckGo.

Kẻ tấn công có thể sử dụng các toán tử tìm kiếm nâng cao có sẵn trong các công cụ tìm kiếm và tạo các truy vấn phức tạp để tìm, lọc và sắp xếp thông tin cụ thể liên quan đến mục tiêu. Công cụ tìm kiếm cũng có thể được dùng để tìm các nguồn thông tin công khai. Ví dụ, bạn có thể gõ “top job portals” để tìm các cổng việc làm có thể cung cấp thông tin quan trọng về tổ chức mục tiêu.

Với vai trò ethical hacker, nếu bạn tìm thấy các trang/thông tin đã bị xóa về công ty mình trong SERP hoặc bộ nhớ đệm của công cụ tìm kiếm, bạn có thể yêu cầu công cụ tìm kiếm xóa các trang/thông tin đó khỏi chỉ mục.

Google hacking đề cập đến việc sử dụng các toán tử tìm kiếm nâng cao của Google để tạo các truy vấn phức tạp nhằm trích xuất thông tin nhạy cảm hoặc ẩn. Thông tin truy cập được sau đó có thể được kẻ tấn công sử dụng để tìm các mục tiêu có lỗ hổng. Footprinting bằng các kỹ thuật Google hacking nâng cao liên quan đến việc xác định các chuỗi văn bản cụ thể trong kết quả tìm kiếm bằng các toán tử nâng cao trong công cụ Google.

Bảng “Các toán tử tìm kiếm Google nâng cao phổ biến” minh họa một số toán tử thường dùng như cache:, [link:], [related:], [info:], [location:] và các toán tử liên quan khác.

Trang 13 (theo PDF gốc)

Google hacking nâng cao là nghệ thuật tạo các truy vấn công cụ tìm kiếm phức tạp. Các truy vấn có thể truy xuất dữ liệu có giá trị về một công ty mục tiêu từ kết quả tìm kiếm Google. Thông qua Google hacking, kẻ tấn công cố gắng tìm các website có lỗ hổng để khai thác. Kẻ tấn công có thể sử dụng Google Hacking Database (GHDB), một cơ sở dữ liệu truy vấn, để xác định dữ liệu nhạy cảm. Các toán tử Google giúp tìm văn bản cần thiết và tránh kết quả không liên quan. Sử dụng toán tử tìm kiếm nâng cao, kẻ tấn công có thể xác định các chuỗi văn bản cụ thể của các ứng dụng web dễ bị tấn công. Khi một truy vấn không có toán tử tìm kiếm nâng cao được nhập, Google lần theo các cụm từ tìm kiếm ở bất kỳ phần nào của trang web, gồm tiêu đề, văn bản, URL, liên kết số, v.v. Để tinh chỉnh tìm kiếm, Google cung cấp các toán tử tìm kiếm nâng cao. Các toán tử này giúp thu hẹp kết quả để tạo ra đầu ra tìm kiếm chính xác và phù hợp nhất.

Cú pháp sử dụng một toán tử tìm kiếm nâng cao là: operator:search_term

Lưu ý: Không nhập khoảng trắng giữa toán tử và truy vấn.

Một số toán tử tìm kiếm Google nâng cao phổ biến:

- site: Giới hạn kết quả tìm kiếm trong website hoặc tên miền được chỉ định. Ví dụ, [site:www.certifiedhacker.com] trả về thông tin về các trang từ certifiedhacker.com.
- allinurl: Giới hạn kết quả chỉ còn các trang chứa tất cả từ khóa được chỉ định trong URL. Ví dụ, [allinurl: google Career] chỉ trả về các trang chứa “google” và “career” trong URL.
- inurl: Giới hạn kết quả chỉ còn các trang chứa từ được chỉ định trong URL. Ví dụ, [inurl: copy site:www.google.com] trả về các trang Google trong đó URL có từ “copy”.
- intext: Giới hạn kết quả chỉ còn các trang chứa từ khóa được chỉ định trong nội dung trang. Ví dụ, [intext:"vpn configuration"] trả về các trang có “vpn configuration” trong phần nội dung.
- allintext: Giới hạn kết quả chỉ còn các trang chứa tất cả từ khóa được chỉ định trong tiêu đề/nội dung theo điều kiện của toán tử. Ví dụ, [allintext: detect malware] trả về các trang có cả “detect” và “malware”.

Trang 14 (theo PDF gốc)

- intitle: Giới hạn kết quả chỉ còn các trang chứa cụm từ được chỉ định trong tiêu đề. Ví dụ, [malware detection intitle:help] chỉ trả về các trang có “help” trong tiêu đề và các từ “malware” và “detection” ở bất kỳ đâu trên trang.
- inanchor: Giới hạn kết quả chỉ còn các trang chứa các từ truy vấn được chỉ định trong văn bản neo của liên kết trỏ đến trang. Ví dụ, [Anti-virus inanchor:Norton] trả về các trang có văn bản neo “Norton” và trang chứa “Anti-virus”.
- allinanchor: Giới hạn kết quả chỉ còn các trang chứa tất cả các từ truy vấn được chỉ định trong văn bản neo của các liên kết trỏ đến trang. Ví dụ, [allinanchor: best cloud service provider] chỉ trả về các trang có các từ “best”, “cloud”, “service”, “provider” trong văn bản neo.
- cache: Hiển thị phiên bản được Google lưu trong bộ nhớ đệm của một trang web tại thời điểm gần nhất. Ví dụ, [cache:www.eff.org] hiển thị phiên bản Google cache của trang Electronic Frontier Foundation.
- link: Tìm các website hoặc trang có liên kết đến website hoặc trang được chỉ định. Ví dụ, [link:www.googleguide.com] tìm các trang liên kết đến trang chủ Google Guide. Lưu ý: Theo tài liệu của Google, không thể kết hợp tìm kiếm link: với truy vấn từ khóa thông thường; khi kết hợp link: với toán tử nâng cao khác, Google có thể không trả về tất cả các trang khớp.
- related: Hiển thị các website tương tự hoặc có liên quan đến URL được chỉ định. Ví dụ, [related:www.microsoft.com] cung cấp kết quả tương tự các website liên quan đến microsoft.com.
- info: Tìm thông tin về trang web được chỉ định. Ví dụ, [info:gothotel.com] cung cấp thông tin về tên miền thư mục khách sạn quốc gia GotHotel.com.
- location: Tìm thông tin cho một vị trí cụ thể. Ví dụ, [location: 4 seasons restaurant] trả về kết quả dựa trên cụm “4 seasons restaurant”.

Trang 15 (theo PDF gốc)

- filetype: Cho phép tìm kết quả theo phần mở rộng tệp. Ví dụ, [Jasmine.jpg] sẽ cung cấp các tệp jpg dựa trên “Jasmine”.
- source: Hiển thị thông tin từ một website cụ thể trong Google News. Ví dụ, [Malware news source:"Hacker News"] trả về các bài từ Hacker News có từ “Malware”.
- phonebook: Tìm số điện thoại nhà riêng và doanh nghiệp của một người hoặc tổ chức. Ví dụ, [phonebook:Sundar Pichai] sẽ cung cấp số điện thoại của Sundar Pichai nếu có trong chỉ mục.
- before: Lọc kết quả chỉ còn nội dung được xuất bản trước một ngày được chỉ định. Ví dụ, [ransomware before:2020-06-29] trả về kết quả về ransomware xuất hiện trước ngày 29/06/2020.
- after: Tìm thông tin được xuất bản sau một ngày nhất định. Ví dụ, [site:wikipedia.org after:2023-01-01 artificial intelligence] truy xuất các bài viết liên quan đến trí tuệ nhân tạo của Wikipedia được xuất bản sau ngày 01/01/2023.

Kẻ tấn công có thể làm gì với Google Hacking?

Kẻ tấn công có thể tạo các truy vấn công cụ tìm kiếm phức tạp để lọc lượng lớn kết quả tìm kiếm nhằm thu thập thông tin hoặc tìm kiếm các lỗ hổng bảo mật của tổ chức mục tiêu. Kẻ tấn công không chỉ có thể phát hiện các website và máy chủ web dễ bị khai thác mà còn có thể xác định vị trí dữ liệu riêng tư và nhạy cảm về tổ chức mục tiêu. Khi một website có thể bị xác định, kẻ tấn công cố gắng phát động nhiều cuộc tấn công, chẳng hạn buffer overflow và SQL injection, làm tổn hại an toàn thông tin.

Ví dụ về thông tin nhạy cảm trên các máy chủ công khai mà kẻ tấn công có thể trích xuất bằng GHDB gồm:

- Thông báo lỗi chứa thông tin nhạy cảm.
- Tệp chứa mật khẩu.
- Thư mục nhạy cảm.
- Trang chứa cổng đăng nhập.
- Trang chứa dữ liệu mạng hoặc lỗ hổng như IDS, nhật ký tường lửa và cấu hình.
- Khuyến cáo và lỗ hổng máy chủ.
- Thông tin phiên bản phần mềm.
- Mã nguồn ứng dụng web.
- Thiết bị IoT được kết nối và bảng điều khiển của chúng nếu không được bảo vệ.
- Các trang web ẩn như dịch vụ intranet và VPN.

Trang 16 (theo PDF gốc)

Ví dụ: Sử dụng cú pháp toán tử Google nâng cao {intitle:intranet inurl:intranet +intext:"human resources"} để tìm thông tin nhạy cảm về một tổ chức mục tiêu và nhân viên của tổ chức đó. Kẻ tấn công sử dụng thông tin thu được để thực hiện các cuộc tấn công social engineering.

Ảnh chụp màn hình minh họa trang kết quả Google cho truy vấn nâng cao nói trên.

Hình 2.2: Kết quả công cụ tìm kiếm cho cú pháp Google Advanced Operator đã cho.

Trang 17 (theo PDF gốc)

FOOTPRINTING BẰNG CÁC KỸ THUẬT GOOGLE HACKING NÂNG CAO VỚI AI

Kẻ tấn công có thể tận dụng các công nghệ hỗ trợ AI để nâng cao và tự động hóa các tác vụ footprinting. Với sự hỗ trợ của AI, kẻ tấn công có thể dễ dàng sử dụng các kỹ thuật Google hacking nâng cao để thu thập những hiểu biết có giá trị về mục tiêu.

Ví dụ, kẻ tấn công có thể dùng công nghệ hỗ trợ AI như ShellGPT để thực hiện tác vụ này bằng prompt phù hợp, chẳng hạn:

“Use filetype search operator to obtain pdf files on the target website eccouncil.org and store the result in the recon1.txt file”

(Dùng toán tử tìm kiếm filetype để lấy các tệp PDF trên website mục tiêu eccouncil.org và lưu kết quả vào tệp recon1.txt.)

Hình 2.3: Prompt cho Google Hacking nâng cao với AI.

Trang 18 (theo PDF gốc)

Lệnh shell sau được thiết kế để thực hiện Google hacking nâng cao bằng toán tử “filetype” nhằm nhắm cụ thể vào các tệp PDF trong miền eccouncil.org. Lệnh sau đó lưu các kết quả thu được vào tệp có tên “recon1.txt”:

```
lynx --dump "http://www.google.com/search?q=site%3Aeccouncil.org%20filetype%3Apdf" | grep "http" | cut -d "=" -f2 | grep -o "http[^&]*" > recon1.txt
```

Giải thích lệnh:

- lynx --dump "http://www.google.com/search?...": Khởi tạo trình duyệt web Lynx ở chế độ dump để truy cập kết quả Google cho các tệp PDF trong miền eccouncil.org.
- | grep "http": Lọc các dòng chứa chuỗi “http” từ đầu ra Lynx.
- | cut -d "=" -f2: Tách từng dòng bằng dấu phân cách “=” và chọn trường thứ hai.
- | grep -o "http[^&]*": Tìm các mẫu bắt đầu bằng “http” và theo sau bởi bất kỳ ký tự nào ngoại trừ “&”.
- > recon1.txt: Chuyển hướng đầu ra cuối cùng vào tệp recon1.txt để lưu trữ.

Hình 2.4: Đầu ra của Google Hacking nâng cao với AI.

Trang 19 (theo PDF gốc)

GOOGLE HACKING DATABASE

Nguồn: https://www.exploit-db.com/google-hacking-database

Google Hacking Database (GHDB) là một bộ sưu tập các Google dork, Google search query được sử dụng để tìm thông tin nhạy cảm vô tình bị lộ trên web. Các truy vấn này khai thác các toán tử tìm kiếm nâng cao của Google để phát hiện:

- Tệp nhạy cảm: Chẳng hạn tệp cấu hình, kết xuất cơ sở dữ liệu và tệp nhật ký có thể chứa tên người dùng, mật khẩu hoặc dữ liệu bí mật khác.
- Thư mục bị lộ: Các thư mục mở trên máy chủ web có thể chứa thông tin nhạy cảm.
- Thông báo lỗi: Thông báo lỗi của máy chủ web hoặc ứng dụng có thể tiết lộ cấu hình máy chủ hoặc lỗ hổng.
- Thiết bị dễ bị tấn công: Xác định các loại thiết bị hoặc phiên bản phần mềm cụ thể được biết có lỗ hổng.

Các danh mục Google Hacking Database:

- Footholds.
- Tệp chứa tên người dùng.
- Thư mục nhạy cảm.
- Phát hiện máy chủ web.
- Tệp dễ bị tấn công.
- Máy chủ dễ bị tấn công.
- Thông báo lỗi.
- Tệp chứa thông tin “juicy”.
- Tệp chứa mật khẩu.
- Tệp chứa thông tin mua sắm.
- Dữ liệu mạng hoặc lỗ hổng.
- Trang chứa cổng đăng nhập.
- Thư mục trực tuyến khác nhau.
- Khuyến cáo và lỗ hổng.

Trang 20 (theo PDF gốc)

Hình 2.5: Ảnh chụp màn hình Google Hacking Database.

Kẻ tấn công có thể tận dụng GHDB theo nhiều cách để xác định và khai thác lỗ hổng:

- Reconnaissance: Kẻ tấn công dùng truy vấn GHDB để thu thập thông tin về mục tiêu tiềm năng, gồm tệp, thư mục và thiết bị bị lộ có thể khai thác.
- Khai thác cấu hình sai: Bằng cách xác định thông tin nhạy cảm bị lộ qua máy chủ hoặc dịch vụ cấu hình sai, kẻ tấn công có thể khai thác các cấu hình sai này để giành quyền truy cập trái phép.
- Tìm hệ thống có lỗ hổng: Dùng GHDB, kẻ tấn công có thể xác định hệ thống chạy phần mềm hoặc phiên bản lỗi thời có lỗ hổng đã biết, tạo điểm khởi đầu cho khai thác tiếp theo.
- Thu thập thông tin xác thực: Thông tin nhạy cảm tìm được qua truy vấn GHDB có thể bao gồm tên người dùng và mật khẩu, thứ mà kẻ tấn công có thể dùng cho credential stuffing hoặc brute-force.
- Xác định cổng và dịch vụ mở: Một số truy vấn GHDB có thể tiết lộ cổng và dịch vụ mở trên mạng, cung cấp cho kẻ tấn công bản đồ các điểm xâm nhập tiềm năng.

Kẻ tấn công cũng sử dụng công cụ SearchSploit, một ứng dụng dòng lệnh để tìm kiếm Exploit-DB cho phép lấy bản sao cơ sở dữ liệu khai thác để sử dụng ngoại tuyến. Nó cho phép kẻ tấn công tìm kiếm chi tiết trong bản sao đã kiểm tra cục bộ. Khả năng này đặc biệt hữu ích cho đánh giá bảo mật trong môi trường không có truy cập Internet.

Trang 21 (theo PDF gốc)

VPN FOOTPRINTING THÔNG QUA GOOGLE HACKING DATABASE

Các toán tử Google hacking hoặc Google dork có thể được dùng cho footprinting mạng riêng ảo (VPN). Chúng cung cấp thông tin như các trang chứa cổng đăng nhập và thư mục có khóa VPN.

Bảng 2.1 - Một số truy vấn Google để footprinting VPN:

- inurl:"/sslvpn_logon.shtml" intitle:"User Authentication" "WatchGuard Technologies" -> Tìm trang có cổng đăng nhập.
- inurl:/sslvpn/Login/Login hoặc site:vpn.* intitle:"login" -> Tìm cổng đăng nhập VPN.
- Các truy vấn chứa chuỗi model/firmware Zyxel và “password vulnerability” -> Tìm host có mật khẩu hardcoded/lỗ hổng mật khẩu Zyxel.
- intext:Please Login SSL VPN inurl:remote/login intext:FortiClient -> Tìm trang đăng nhập Fortinet VPN.
- site:vpn.* intitle:"login" -> Truy xuất nhiều trang đăng nhập VPN.
- intitle:"index of" /etc/openvpn/ và chuỗi “BEGIN OpenVPN Static key V1” ext:key -> Lấy thông tin thư mục và khóa OpenVPN.
- intitle:"index of" "vpn-config.*" -> Truy xuất thông tin VPN cụ thể.
- index of /*.ovpn -> Tìm tệp cấu hình OpenVPN, một số có chứng chỉ và khóa.
- inurl:"/vpn/tmindex.html" vpn -> Tìm cổng đăng nhập Netscaler và Citrix Gateway VPN.
- intitle:"SSL VPN Service" intext:"your system administrator provided the following information to help understand and remedy the security conditions" -> Tìm trang đăng nhập Cisco Adaptive Security Appliance (ASA).

VPN Footprinting thông qua Google Hacking Database với AI

Kẻ tấn công có thể tận dụng công nghệ AI để tăng cường và tự động hóa tác vụ footprinting. Với sự hỗ trợ của AI, kẻ tấn công có thể thực hiện VPN footprinting dễ dàng và thu được thông tin hữu ích.

Trang 22 (theo PDF gốc)

Ví dụ, kẻ tấn công có thể dùng ChatGPT bằng prompt phù hợp:

“Use inurl search operator to obtain the Fortinet VPN login pages”

(Dùng toán tử tìm kiếm inurl để lấy các trang đăng nhập Fortinet VPN.)

Lệnh sau được thiết kế để tìm các trang đăng nhập Fortinet VPN bằng Lynx, trình duyệt web dạng văn bản, cùng với công cụ tìm kiếm Google:

```
lynx --dump "http://www.google.com/search?q=inurl:%22remote+login%22+fortinet+OR+fortigate" |
grep "http" | cut -d "=" -f2 | grep -o "http[^&]*"
```

Lệnh lấy kết quả Google dựa trên truy vấn đã chỉ định, trích URL từ kết quả và sau đó lọc, định dạng URL trước khi hiển thị. Mục tiêu tổng thể là xác định các trang đăng nhập Fortinet VPN từ kết quả tìm kiếm.

Giải thích:

- lynx --dump ...: truy cập trang kết quả Google bằng truy vấn tìm các trang có cụm “remote login” trong URL và Fortinet/Fortigate/SSL VPN trong nội dung.
- | grep "http": lọc các dòng đầu ra chứa chuỗi “http”.
- | cut -d "=" -f2: tách theo “=” và chọn trường thứ hai.

Hình 2.6: Dùng toán tử tìm kiếm inurl để lấy các trang đăng nhập Fortinet VPN.

Trang 23 (theo PDF gốc)

- | grep -o "http[^&]*"': Phần này đưa đầu ra của lệnh trước vào một lệnh grep khác, lệnh này tìm các mẫu bắt đầu bằng “http” và theo sau bởi bất kỳ ký tự nào ngoại trừ “&”.

Trang 24 (theo PDF gốc)

FOOTPRINTING THÔNG QUA CÔNG CỤ TÌM KIẾM SHODAN

Nguồn: https://www.shodan.io

Shodan là một công cụ tìm kiếm mà kẻ tấn công dùng để thực hiện footprinting ở nhiều cấp độ khác nhau. Nó được dùng để phát hiện các thiết bị và mạng có lỗ hổng. Một tìm kiếm trong Shodan cho VoIP và VPN footprinting có thể trả về các kết quả hữu ích, giúp thu thập thông tin liên quan đến IP và VoIP. Các ảnh chụp màn hình minh họa một số kết quả VoIP và VPN thu được qua Shodan.

Trang 25 (theo PDF gốc)

Hình 2.7: Ảnh chụp màn hình công cụ tìm kiếm SHODAN hiển thị kết quả VoIP.

Trang 26 (theo PDF gốc)

Hình 2.8: Ảnh chụp màn hình công cụ tìm kiếm SHODAN hiển thị kết quả VPN.

CÁC KỸ THUẬT KHÁC ĐỂ FOOTPRINTING THÔNG QUA CÔNG CỤ TÌM KIẾM

Thu thập thông tin bằng Google Advanced Search, Advanced Image Search và Reverse Image Search

Kẻ tấn công không phải lúc nào cũng dễ dàng thu thập thông tin từ một website giàu thông tin bằng hộp tìm kiếm thông thường. Một tìm kiếm phức tạp bao gồm nhiều điều kiện liên quan với nhau.

Tính năng tìm kiếm nâng cao của Google giúp kẻ tấn công thực hiện tìm kiếm web phức tạp. Với Google Advanced Search và Advanced Image Search, người ta có thể tìm kiếm web chính xác hơn. Có thể sử dụng các tìm kiếm này để đạt được độ chính xác tương tự như khi dùng toán tử nâng cao mà không cần gõ hoặc nhớ các toán tử.

Trang 27 (theo PDF gốc)

Dùng tùy chọn Advanced Search của Google, bạn có thể tìm các website có thể liên kết trở lại website của tổ chức mục tiêu. Điều này giúp trích xuất thông tin như đối tác, nhà cung cấp, khách hàng và các đơn vị liên kết khác của website mục tiêu. Bạn có thể dùng Google Advanced Image Search để lấy hình ảnh của mục tiêu, vị trí, nhân viên, v.v.

Để thực hiện tìm kiếm nâng cao trong Google, bấm Settings ở góc dưới bên phải trang chủ Google, sau đó chọn Advanced search trong menu hoặc gõ https://www.google.com/advanced_search vào thanh địa chỉ. Advanced search cho phép chỉ định nhiều tiêu chí mà tìm kiếm phải khớp; mẫu này xây dựng trên thanh tìm kiếm để bạn có thêm tùy chọn. Để thực hiện tìm kiếm, bạn có thể điền tất cả, một phần hoặc không điền ô nào. Sau khi nhập truy vấn mong muốn, bấm nút Advanced search. Tìm kiếm này có thể được thực hiện với “all these words” (tất cả những từ này; nghĩa là tất cả từ phải khớp), “this exact word or phrase” (cụm từ chính xác), “any of these words” (bất kỳ từ nào; ít nhất một phải khớp) và “none of these words” (không từ nào được xuất hiện). Các trường dành cho tập hợp, khối và định dạng được nối với nhau bằng “or”.

Hình 2.9: Google Advanced Search.

Trang 28 (theo PDF gốc)

Để thực hiện tìm kiếm hình ảnh nâng cao trong Google, nhập https://www.google.com/advanced_image_search vào thanh địa chỉ. Advanced Image Search cho phép tinh chỉnh tìm kiếm hình ảnh theo nhiều cách. Bạn có thể tìm theo màu sắc hình ảnh, miền, loại tệp, kích thước, từ khóa, v.v. Để thực hiện, chọn một trường, sau đó nhập chuỗi cần tìm vào các trường đó và bấm Advanced Search.

Hình 2.10: Google Advanced Image Search.

Trang 29 (theo PDF gốc)

Để thực hiện reverse image search trong Google, nhập https://www.google.com/imghp vào thanh địa chỉ. Reverse image search cho phép sử dụng một hình ảnh làm truy vấn tìm kiếm. Bạn có thể tải ảnh lên hoặc dán URL của ảnh vào công cụ reverse image search. Công cụ tìm kiếm sẽ tìm trên web và hiển thị tất cả vị trí trực tuyến của ảnh đó trong kết quả tìm kiếm. Kết quả được trả về có thể giúp truy tìm nguồn gốc và chi tiết của hình ảnh, chẳng hạn ảnh chụp, ảnh hồ sơ và meme.

Kẻ tấn công cũng có thể dùng các công cụ trực tuyến như Google Image Search, TinEye Reverse Image Search, Yahoo Image Search, Bing Image Search và Pinterest Reverse Image Search để thực hiện reverse image search.

Hình 2.11: Reverse Image Search bằng Google.

Thu thập thông tin từ công cụ tìm kiếm video

Công cụ tìm kiếm video là công cụ tìm kiếm dựa trên Internet quét web để tìm nội dung video. Chúng cung cấp chức năng tải lên và lưu trữ nội dung video trên máy chủ web hoặc cung cấp nội dung video được lưu trữ ở nơi khác. Nội dung video thu được từ công cụ tìm kiếm trực tuyến có thể rất lớn, vì có thể được lập chỉ mục từ các nền tảng lưu trữ lớn. Các công cụ như YouTube, Google Videos, Yahoo Videos và Bing Videos cho phép kẻ tấn công tìm nội dung video dựa trên định dạng và thời lượng.

Trang 30 (theo PDF gốc)

Hình 2.12: Ảnh chụp màn hình YouTube hiển thị kết quả tìm kiếm cho Microsoft.

Sau khi tìm video liên quan đến mục tiêu bằng các công cụ tìm kiếm video, kẻ tấn công có thể phân tích thêm nội dung video để thu thập thông tin ẩn như metadata và thumbnail của video. Sử dụng các công cụ phân tích video như MetaData, YouTube DataViewer, MW Metadata, EZGif và VideoReverser.com, kẻ tấn công có thể reverse video hoặc chuyển video thành văn bản và các định dạng khác để trích xuất thông tin quan trọng về mục tiêu.

Trang 31 (theo PDF gốc)

Hình 2.13: Ảnh chụp màn hình YouTube Metadata hiển thị kết quả phân tích video.

Thu thập thông tin từ Meta Search Engines

Meta search engine là loại công cụ tìm kiếm khác sử dụng các công cụ tìm kiếm khác (Google, Bing, Ask.com, v.v.) để tạo ra kết quả từ Internet theo cách rất ngắn. Các công cụ này không có chỉ mục hoặc cú pháp riêng; thay vào đó, chúng nhận đầu vào từ người dùng và đồng thời gửi truy vấn tới các công cụ tìm kiếm bên thứ ba để lấy kết quả. Khi thu thập đủ kết quả, chúng được xếp hạng theo mức độ liên quan và trình bày cho người dùng. Meta search engine còn có chức năng lọc các kết quả giống hệt nhau; nếu người dùng tìm một truy vấn mơ hồ, nó có thể hiển thị các kết quả giống nhau nhiều lần. Meta search engine tận dụng tài nguyên của nhiều công cụ tìm kiếm; nó có thể truy xuất nhiều kết quả với cùng mức công sức.

Sử dụng các meta search engine như Startpage, MetaGer và eTools.ch, kẻ tấn công có thể gửi nhiều truy vấn tới nhiều công cụ tìm kiếm đồng thời và thu thập thông tin quan trọng như thông tin thu được từ các website mua sắm lớn (Amazon, eBay, BestBuy, v.v.), hình ảnh, video, blog, tin tức và bài viết từ các nguồn khác nhau.

Trang 32 (theo PDF gốc)

Ngoài ra, meta search engine còn cung cấp quyền riêng tư cho người dùng bằng cách ẩn địa chỉ IP của người dùng.

Hình 2.14: Ảnh chụp màn hình Meta Search Engine StartPage.com hiển thị kết quả tìm kiếm Facebook.

Thu thập thông tin từ công cụ tìm kiếm File Transfer Protocol (FTP)

Công cụ tìm kiếm FTP được dùng để tìm tệp nằm trên máy chủ FTP chứa thông tin có giá trị về tổ chức mục tiêu. Nhiều ngành, tổ chức, công ty và trường đại học sử dụng máy chủ FTP để lưu trữ tệp và thư mục và chia sẻ chúng giữa nhân viên. Một trình khách đặc biệt như FileZilla (https://filezilla-project.org) có thể được dùng để truy cập tài khoản FTP; nó cũng hỗ trợ các chức năng như tải lên, tải xuống và đổi tên tệp. Mặc dù máy chủ FTP thường được bảo vệ bằng mật khẩu, nhiều máy chủ bị để không an toàn và có thể được truy cập trực tiếp bằng trình duyệt web.

Sử dụng các công cụ tìm kiếm FTP như NAPALM FTP Indexer, FreewareWeb FTP File Search, Mamont và Globalfilesearch.com, kẻ tấn công có thể tìm các tệp và thư mục quan trọng chứa thông tin có giá trị như chiến lược kinh doanh, tài liệu thuế, hồ sơ nhân sự, bạn bè, tài chính cá nhân, phần mềm cấp phép và các thông tin bí mật khác.

Trang 33 (theo PDF gốc)

Một số truy vấn Google nâng cao quan trọng để tìm máy chủ FTP được liệt kê trong Bảng 2.2. Các truy vấn dùng các mẫu như:

- site:.in | .com | .net intitle:"index of" ftp
- intitle:"index of" "*/ftp.txt"
- intext:"index of" "ftp"
- inurl:WS_FTP.log
- intitle:index.of /ftp/robots.txt
- intitle:"Index of ftp passwords"
- inurl:/ftp intitle:"office"
- inurl:/web-ftp.cgi
- site:sftp.* intitle:"server login"
- intitle:"index of" ws_ftp.ini
- inurl:ftp -inurl:http|https intext:"@gmail.com" intext:subject ...
- allintitle:"CrushFTP WebInterface"
- "ws_ftp.log" ext:log
- intitle:"Monsta ftp" intext:"Lock session to IP"
- "index of" /ftp/logs
- intitle:"index of" inurl:ftp intext:admin

Mô tả tương ứng gồm: tìm tệp chứa thông tin hấp dẫn, tệp chứa mật khẩu, phát hiện máy chủ web, trang có cổng đăng nhập, tệp cấu hình/nhật ký FTP, thư mục nhạy cảm, website sử dụng Monsta FTP, tệp nhật ký tiềm năng và thư mục quản trị trên máy chủ FTP.

Trang 34 (theo PDF gốc)

Như trong ảnh chụp màn hình, kẻ tấn công có thể dùng NAPALM FTP Indexer, một công cụ trực tuyến, để tìm các tệp hoặc tài liệu quan trọng liên quan đến miền mục tiêu.

Hình 2.15: Ảnh chụp màn hình NAPALM FTP Indexer hiển thị kết quả tìm kiếm cho “microsoft”.

Thu thập thông tin từ công cụ tìm kiếm IoT

Internet of Things (IoT) search engine quét toàn bộ Internet để tìm các thiết bị IoT có thể truy cập công khai. Thông qua tìm kiếm cơ bản trên các công cụ này, kẻ tấn công có thể giành quyền kiểm soát hệ thống Supervisory Control and Data Acquisition (SCADA), camera giao thông, hệ thống Internet-connected household appliances, công nghiệp, CCTV, v.v. Nhiều thiết bị IoT không an toàn, tức là không được mã hóa hoặc không có mật khẩu mặc định, có thể bị hacker khai thác.

Với sự trợ giúp của các công cụ tìm kiếm IoT như Shodan, Censys và ZoomEye, kẻ tấn công có thể thu thập thông tin như chi tiết nhà sản xuất, vị trí địa lý, địa chỉ IP, hostname và các cổng mở của thiết bị IoT mục tiêu. Dùng thông tin này, kẻ tấn công có thể thiết lập backdoor vào thiết bị IoT và truy cập chúng để phát động các cuộc tấn công tiếp theo.

Trang 35 (theo PDF gốc)

Như trong ảnh chụp màn hình, kẻ tấn công có thể dùng Shodan để tìm tất cả thiết bị IoT của tổ chức mục tiêu có cổng và dịch vụ đang mở.

Hình 2.16: Ảnh chụp màn hình Shodan hiển thị kết quả tìm kiếm cho thiết bị SCADA.

Trang 36 (theo PDF gốc)

Hình 2.17: Ảnh chụp màn hình Shodan hiển thị các cổng và dịch vụ mở của một hệ thống SCADA.

Trang 37 (theo PDF gốc)

Mục tiêu 03: Minh họa Footprinting thông qua các dịch vụ nghiên cứu Internet

Reconnaissance thụ động

FOOTPRINTING THÔNG QUA CÁC DỊCH VỤ NGHIÊN CỨU INTERNET

Các dịch vụ nghiên cứu Internet như people search service có thể cung cấp thông tin nhạy cảm về mục tiêu. People search service, alerting service, financial service và job site cung cấp thông tin về mục tiêu như chi tiết hạ tầng, vị trí vật lý và chi tiết nhân viên. Dùng thông tin này, kẻ tấn công có thể xây dựng chiến lược hacking để xâm nhập mạng của tổ chức và thực hiện các kiểu tấn công hệ thống nâng cao khác.

Phần này nhằm giúp bạn làm quen với việc tìm top-level domain, subdomain và vị trí địa lý của công ty; thực hiện people search trên people search service; thu thập thông tin từ job site, financial service, website bên thứ ba; thực hiện dark web footprinting; thu thập competitive intelligence, v.v.

Trang 38 (theo PDF gốc)

TÌM TOP-LEVEL DOMAIN (TLD) VÀ SUBDOMAIN CỦA CÔNG TY

Top-level domain (TLD) và subdomain của một công ty có thể cung cấp lượng lớn thông tin hữu ích cho kẻ tấn công. Một website được thiết kế để thể hiện sự hiện diện của tổ chức trên Internet. Nó có thể truy cập công khai và được tạo ra để thu hút khách hàng và đối tác. Nó có thể chứa thông tin của tổ chức như lịch sử, dịch vụ và sản phẩm, chi tiết liên hệ và các thông tin tổ chức khác. Bạn có thể tìm top-level domain của công ty bằng Google và Bing.

Trang 39 (theo PDF gốc)

Hình 2.18: Google Search hiển thị kết quả cho các miền do Microsoft sở hữu.

Subdomain chỉ có thể truy cập đối với một số người. Những người này có thể là nhân viên của tổ chức hoặc thành viên một bộ phận. Trong nhiều tổ chức, quản trị viên website tạo subdomain để kiểm thử công nghệ trước khi triển khai trên website chính. Thông thường, subdomain nằm trong phạm vi mục tiêu và là miền dễ bị tấn công. Subdomain cung cấp cái nhìn về các bộ phận và đơn vị kinh doanh khác nhau trong một tổ chức. Việc xác định các subdomain như vậy có thể tiết lộ thông tin quan trọng về mục tiêu, chẳng hạn mã nguồn của website và nội dung của website. Có thể áp dụng các hạn chế truy cập dựa trên địa chỉ IP, miền hoặc subnet, username và password. Subdomain giúp truy cập các chức năng riêng của tổ chức. Phần lớn tổ chức dùng tên phổ biến cho subdomain. Do đó, hacker biết tên miền ngoài của công ty thường có thể phát hiện subdomain bằng thử-sai hoặc sử dụng dịch vụ như Netcraft.

Bạn cũng có thể dùng toán tử Google nâng cao sau để xác định tất cả subdomain của mục tiêu:

site:microsoft.com -inurl:www

Trang 40 (theo PDF gốc)

Hình 2.19: Tìm subdomain bằng toán tử Google Advanced Search.

CÔNG CỤ TÌM SUBDOMAIN CỦA CÔNG TY

Netcraft

Nguồn: https://www.netcraft.com

Netcraft cung cấp các dịch vụ bảo mật Internet, bao gồm chống gian lận và chống phishing, kiểm thử ứng dụng và quét PCI. Công cụ này có thể phân tích thị phần của máy chủ web, hệ điều hành, nhà cung cấp hosting và chứng chỉ SSL đối với các tham số khác nhau của Internet.

Như ảnh chụp màn hình sau, kẻ tấn công có thể dùng Netcraft để thu được tất cả subdomain liên quan đến miền mục tiêu.

Trang 41 (theo PDF gốc)

Hình 2.20: Ảnh chụp màn hình Netcraft hiển thị các subdomain của microsoft.com.

DNSdumpster

Nguồn: https://dnsdumpster.com

DNSdumpster.com là công cụ nghiên cứu miền có thể được kẻ tấn công sử dụng để phát hiện các host liên quan đến một miền.

Như trong ảnh chụp màn hình, kẻ tấn công tìm các subdomain liên quan đến microsoft.com để thu được thông tin quan trọng về miền công ty mục tiêu như subdomain, địa chỉ IP, máy chủ DNS, v.v.

Trang 42 (theo PDF gốc)

Hình 2.21: Ảnh chụp màn hình DNSdumpster hiển thị subdomain của eccouncil.org.

Pentest-Tools Find Subdomains

Nguồn: https://pentest-tools.com

Pentest-Tools Find Subdomains là một công cụ trực tuyến dùng để phát hiện subdomain và địa chỉ IP của chúng, bao gồm thông tin mạng liên quan và HTTP server.

Như ảnh chụp màn hình, kẻ tấn công tìm các subdomain liên quan đến microsoft.com để thu được thông tin quan trọng về miền công ty mục tiêu, chẳng hạn subdomain, địa chỉ IP, hệ điều hành, cổng mở, người dùng, công nghệ sử dụng, nền tảng web và tiêu đề trang.

Trang 43 (theo PDF gốc)

Hình 2.22: Ảnh chụp màn hình Pentest-Tools hiển thị các subdomain của microsoft.com.

Trang 44 (theo PDF gốc)

TÌM TOP-LEVEL DOMAIN (TLD) VÀ SUBDOMAIN CỦA CÔNG TY VỚI AI

Kẻ tấn công có thể tận dụng công nghệ hỗ trợ AI để nâng cao và tự động hóa tác vụ footprinting. Với sự hỗ trợ của AI, kẻ tấn công có thể dễ dàng tìm top-level domain và subdomain của mục tiêu.

Ví dụ #1

Kẻ tấn công có thể dùng ChatGPT để thực hiện tác vụ bằng prompt phù hợp:

“Discover all the subdomains of ‘google.com’ using dig command.”

(Khám phá tất cả subdomain của google.com bằng lệnh dig.)

Hình 2.23: Khám phá tất cả subdomain của google.com bằng lệnh dig.

Trang 45 (theo PDF gốc)

Lệnh này yêu cầu dig truy vấn các authoritative name server (bản ghi NS) cho google.com và hiển thị phản hồi. Đầu ra liệt kê tất cả name server liên quan đến google.com, thường cũng bao gồm các subdomain.

Lệnh ví dụ:

```
dig +short google.com NS | xargs -I {} dig +nocmd +noall +answer @{} google.com
```

Giải thích:

- dig +short google.com NS: truy xuất bản ghi name server (NS) cho google.com ở định dạng rút gọn.
- | xargs -I {}: lấy từng dòng đầu ra (mỗi dòng đại diện một name server) và truyền làm đối số cho lệnh dig tiếp theo.
- dig +nocmd +noall +answer @{} google.com: thực hiện truy vấn DNS tới từng name server thu được từ lệnh trước và chỉ hiển thị phần answer, nhằm lấy các địa chỉ IP/subdomain liên quan.

Ví dụ #2

Kẻ tấn công có thể dùng ChatGPT bằng prompt phù hợp:

“Use Sublist3r to gather a list of subdomains of the target organization eccouncil”

(Dùng Sublist3r để thu thập danh sách subdomain của tổ chức mục tiêu eccouncil.)

Lệnh:

```
sublist3r -d eccouncil.org -o eccouncil_subdomains.txt
```

Giải thích:

- sublist3r: lệnh dùng để thực thi công cụ Sublist3r.
- -d eccouncil.org: chỉ định miền mục tiêu là eccouncil.org.
- -o eccouncil_subdomains.txt: chỉ định tệp đầu ra để lưu các subdomain đã liệt kê.

Hình 2.24: Dùng Sublist3r để thu thập danh sách subdomain của tổ chức mục tiêu eccouncil.

Trang 46 (theo PDF gốc)

Hình 2.25: Các subdomain liên quan đến mục tiêu.

Hình 2.26: Các subdomain liên quan đến mục tiêu.

Nhìn chung, lệnh trên yêu cầu Sublist3r tìm các subdomain liên quan đến miền eccouncil.org và lưu kết quả vào tệp văn bản eccouncil_subdomains.txt.

Trang 47 (theo PDF gốc)

TRÍCH XUẤT THÔNG TIN WEBSITE TỪ https://archive.org

Internet Archive's Wayback Machine cho phép bạn xem các phiên bản lưu trữ của website.

Nguồn: https://archive.org

Archive là một dịch vụ Internet Archive Wayback Machine khám phá các phiên bản website được lưu trữ. Khám phá như vậy cho phép kẻ tấn công thu thập thông tin về các trang web của một tổ chức kể từ khi chúng được tạo ra. Tại website https://archive.org, người ta lưu giữ lịch sử các trang web từ thời điểm tạo ra; kẻ tấn công có thể truy xuất ngay cả thông tin đã bị xóa khỏi website mục tiêu, chẳng hạn trang web cũ, tệp âm thanh, tệp video, hình ảnh, văn bản và chương trình phần mềm. Kẻ tấn công dùng thông tin này để thực hiện phishing và các kiểu tấn công ứng dụng web khác đối với tổ chức mục tiêu.

Trang 48 (theo PDF gốc)

Hình 2.27: Ảnh chụp màn hình Archive hiển thị các phiên bản được lưu trữ của microsoft.com.

Hình 2.28: Ảnh chụp màn hình Archive hiển thị các trang web được lưu trữ của microsoft.com.

Trang 49 (theo PDF gốc)

Kẻ tấn công có thể sử dụng công cụ như Photon để truy xuất URL lưu trữ của website mục tiêu từ archive.org. Chạy lệnh sau để truy xuất liên kết lưu trữ của website mục tiêu:

```
photon.py -u <URL of the Target Website> -l 3 -t 200 --wayback
```

Hình 2.29: Ảnh chụp màn hình Photon hiển thị đầu ra của lệnh truy xuất các liên kết lưu trữ.

Chạy lệnh sau để chỉ truy xuất URL lưu trữ của website mục tiêu:

```
python photon.py -u <URL of the Target Website> -l 3 -t 200 --only-urls
```

Hình 2.30: Ảnh chụp màn hình Photon hiển thị đầu ra lệnh truy xuất URL lưu trữ.

Trang 50 (theo PDF gốc)

FOOTPRINTING THÔNG QUA PEOPLE SEARCH SERVICES VÀ JOB SITES

People search service như Spokeo, Intelius và BeenVerified có thể tiết lộ chi tiết liên hệ, lịch sử giao tiếp, quá khứ của một người hoặc tổ chức, vị trí ẩn, địa chỉ email, blog, liên hệ mạng, hồ sơ, v.v.

Job site như Dice, LinkedIn và Glassdoor có thể tiết lộ thông tin về kỹ năng kỹ thuật của nhân viên và các dịch vụ tuyển dụng, từ đó hỗ trợ kẻ tấn công xác định lỗ hổng trong môi trường CNTT của mục tiêu.

Footprinting thông qua People Search Services

Bạn có thể dùng các nguồn công khai để tìm thông tin về địa chỉ email, số điện thoại, địa chỉ nhà, thông tin trực tuyến của từng cá nhân, v.v. Nhiều people search service giúp tìm thông tin về người khác. Nói chung, các dịch vụ này như Spokeo, Intelius, Pipl, BeenVerified, Whitepages, Instant Checkmate và PeekYou cung cấp thông tin về địa chỉ, chi tiết liên hệ, ngày sinh, ảnh, video, thông tin nghề nghiệp, hoạt động trên Internet, hồ sơ sức khỏe và tiền sử phạm tội, v.v. Ngoài ra, các people search service trực tuyến thường tiết lộ nghề nghiệp của một cá nhân, doanh nghiệp của người đó, dự án sắp tới và môi trường vận hành, website và blog, số liên hệ quan trọng, số điện thoại di động, số fax và địa chỉ email cá nhân. Với thông tin này, kẻ tấn công có thể cố lấy thông tin ngân hàng, chi tiết thẻ tín dụng, lịch sử quá khứ, v.v. Thông tin này được dùng để thực hiện các cuộc tấn công social engineering nhằm phát động một cuộc tấn công.

People Search Service - Spokeo

Nguồn: https://www.spokeo.com

Kẻ tấn công có thể dùng dịch vụ tìm người trực tuyến Spokeo để tìm người thuộc tổ chức mục tiêu. Dịch vụ này cho phép thu thập thông tin như số điện thoại, địa chỉ email, tuổi, ngày sinh, thành viên gia đình, hồ sơ xã hội và hồ sơ tòa án.

Trang 51 (theo PDF gốc)

Hình 2.31: Ảnh chụp màn hình dịch vụ tìm người Spokeo.

Footprinting thông qua Job Sites

Kẻ tấn công có thể thu thập thông tin có giá trị về hệ điều hành, phiên bản phần mềm, máy chủ của công ty và thông tin cơ sở dữ liệu của một tổ chức thông qua các job site bằng nhiều kỹ thuật. Website của nhiều tổ chức cung cấp thông tin tuyển dụng trong trang đăng việc làm, và điều này thường tiết lộ thông tin phần cứng/phần mềm, thông tin liên quan đến mạng và công nghệ, cũng như bằng cách cung cấp ví dụ như hệ thống e-mail server, hệ điều hành được dùng, thiết bị mạng, hypervisor, VM, v.v. Ngoài ra, website có thể có khóa nhân viên chứa địa chỉ email. Thông tin này có thể có lợi cho kẻ tấn công. Ví dụ, nếu một tổ chức quảng cáo vị trí Network Administrator, nó sẽ đăng các yêu cầu liên quan đến vị trí đó.

Hơn nữa, kẻ tấn công có thể xem hồ sơ nhân viên đăng trên job site và trích xuất thông tin như kỹ năng và chứng chỉ kỹ thuật, trình độ học vấn và lịch sử công việc. Lịch sử công việc của một nhân viên có thể tiết lộ thông tin kỹ thuật về tổ chức mục tiêu. Kẻ tấn công có thể dùng thông tin kỹ thuật thu được thông qua job site như Dice, LinkedIn, Glassdoor và Simply Hired để phát hiện các lỗ hổng trong hạ tầng CNTT của mục tiêu.

Trang 52 (theo PDF gốc)

Hình 2.32: Ảnh chụp màn hình một tin tuyển dụng hiển thị thông tin có giá trị.

Ví dụ tin tuyển dụng “Junior Network Administrator / Assistant” có thể công khai yêu cầu về hệ điều hành, giao thức, firewall, switch/router, VPN, virtualization, backup, troubleshooting và các công nghệ đang được tổ chức sử dụng.

Trang 53 (theo PDF gốc)

DARK WEB FOOTPRINTING

Surface web là lớp ngoài của không gian mạng trực tuyến cho phép người dùng tìm các trang web và nội dung bằng trình duyệt web thông thường. Công cụ tìm kiếm là các chương trình thu thập bot để truy cập và tải xuống các trang web. Surface web có thể truy cập bằng các trình duyệt như Google Chrome, Mozilla Firefox và Opera.

Deep web là lớp không gian mạng trực tuyến gồm các trang web và nội dung bị ẩn và không được lập chỉ mục. Nội dung như vậy không thể được tìm bằng trình duyệt web và công cụ tìm kiếm truyền thống. Kích thước deep web không thể tính chính xác và mở rộng gần như toàn bộ World Wide Web. Deep web không chứa tất cả nội dung; nó cũng bao gồm công cụ tìm kiếm, tạp chí, website khác nhau, website chính phủ và các trang khác nhau của tổ chức.

Deep web có thể được truy cập bằng các công cụ tìm kiếm như Tor Browser và WWW Virtual Library. Nó có thể được dùng cho cả hoạt động hợp pháp và bất hợp pháp.

Dark web hay Darknet là một lớp sâu hơn của không gian mạng trực tuyến, và nó là tập hợp các deep web cho phép bất kỳ ai truy cập ẩn danh mà không bị truy dấu. Dark web chỉ có thể truy cập thông qua các công cụ hoặc darknet browser chuyên dụng. Kẻ tấn công chủ yếu sử dụng dark web để thực hiện footprinting trên tổ chức mục tiêu và phát động tấn công. Dark web có thể được truy cập bằng các công cụ tìm kiếm như Tor Browser và ExoneraTor.

Kẻ tấn công có thể dùng các công cụ tìm kiếm dark web như Tor Browser, ExoneraTor và Onionland để tìm lượng thông tin lớn về mục tiêu, như thông tin thẻ tín dụng, thông tin hộ chiếu, chi tiết giấy tờ nhận dạng, hồ sơ y tế, tài khoản mạng xã hội và Social Security Numbers (SSNs). Với sự trợ giúp của thông tin này, họ có thể phát động thêm các cuộc tấn công vào mục tiêu.

Trang 54 (theo PDF gốc)

Tor Browser

Nguồn: https://www.torproject.org

Tor Browser được dùng để truy cập dark web, nơi nó hoạt động như một VPN mặc định cho người dùng và chuyển lưu lượng mạng qua các máy chủ proxy khác nhau trước khi tương tác với web. Kẻ tấn công dùng trình duyệt này để truy cập nội dung ẩn, website chưa được lập chỉ mục và cơ sở dữ liệu mã hóa hiện diện trên dark web.

Như trong ảnh chụp màn hình, bằng Tor Browser, kẻ tấn công có thể thu được thông tin chi tiết và đầy đủ hơn về tổ chức mục tiêu.

Hình 2.33: Ảnh chụp màn hình Tor Browser.

Tìm kiếm Dark Web bằng Advanced Search Parameters

Kẻ tấn công có thể dùng các tham số tìm kiếm nâng cao để tinh chỉnh tìm kiếm trong Deep Web nhằm tìm dữ liệu cụ thể bằng các công cụ tìm kiếm Dark Web như Tor Browser. Họ có thể tìm thông tin quan trọng bằng tham số tìm kiếm nâng cao như lọc theo loại tệp hoặc đặt hạn chế tìm kiếm.

Ví dụ, kẻ tấn công có thể dùng tham số nâng cao để tìm tài liệu nhạy cảm như hồ sơ tài chính hoặc thông tin đăng nhập. Các kỹ thuật tìm kiếm nâng cao cho phép kẻ tấn công nhanh chóng tìm và truy cập thông tin có giá trị và sử dụng nó để thực hiện hoạt động độc hại.

Trang 55 (theo PDF gốc)

Kẻ tấn công có thể tinh chỉnh tìm kiếm và tập trung vào dữ liệu cụ thể bằng các tham số sau:

- Hồ sơ cá nhân: Tìm thông tin liên quan đến hồ sơ cá nhân của nạn nhân như hồ sơ mạng xã hội hoặc website cá nhân. Ví dụ: “John Doe” site:facebook.com OR site:linkedin.com
- Ấn phẩm khoa học: Tìm các ấn phẩm hoặc bài báo học thuật cụ thể, khoa học. Ví dụ: “John Doe” site:scholar.google.com
- Hồ sơ tòa án: Tìm tài liệu pháp lý liên quan đến hồ sơ hoặc vụ án tòa. Ví dụ: “John Doe” court records
- Danh bạ thành viên: Tìm thư mục các thành viên làm việc trong tổ chức. Ví dụ: “John Doe” site:example.com “employee directory”
- Hồ sơ y tế: Tìm thông tin y tế hoặc lịch sử sức khỏe của nạn nhân. Ví dụ: “John Doe” medical records
- Hồ sơ vị trí: Tìm thông tin vị trí như lịch sử vị trí hoặc thông tin GPS của nạn nhân. Ví dụ: “John Doe” location history

Hình 2.34: Ảnh chụp màn hình Tor Browser hiển thị kết quả tham số tìm kiếm nâng cao.

Trang 56 (theo PDF gốc)

Bảng 2.3 - Các truy vấn tìm kiếm nâng cao để footprinting trên dark web nhằm tìm thông tin nhạy cảm bằng Tor Browser:

- Sensitive PDFs: filetype:pdf site:onion confidential -> Tìm tài liệu PDF được đánh dấu confidential trên các site .onion.
- Passwords in Config Files: inurl:config filetype:txt password -> Tìm tệp văn bản có URL cấu hình chứa mật khẩu.
- Financial Documents: filetype:xlsx site:onion financial -> Tìm tệp Excel liên quan dữ liệu tài chính trên site .onion.
- Database Dumps: filetype:sql site:onion dump -> Tìm tệp dump cơ sở dữ liệu SQL.
- Email Lists: filetype:csv site:onion email -> Tìm CSV chứa danh sách email.
- Login Credentials: intitle:"login credentials" filetype:docx -> Tìm tài liệu Word có thông tin đăng nhập trong tiêu đề.
- Server Configurations: filetype:xml inurl:config server -> Tìm XML liên quan cấu hình server.
- Private Keys: filetype:key site:onion private -> Tìm tệp private key trên site .onion.
- Medical Records: filetype:pdf site:onion "medical records" -> Tìm PDF chứa hồ sơ y tế.
- Business Plans: filetype:ppt site:onion "business plan" -> Tìm PowerPoint về kế hoạch kinh doanh.
- Source Code: filetype:py site:onion "def " -> Tìm mã nguồn Python.
- Legal Documents: filetype:docx site:onion "legal document" -> Tìm tài liệu Word liên quan pháp lý.
- Bank Statements: filetype:pdf site:onion "bank statement" -> Tìm PDF chứa sao kê ngân hàng.
- Intellectual Property: filetype:pdf inurl:patent confidential -> Tìm tài liệu PDF bằng sáng chế được đánh dấu confidential.
- Security Vulnerabilities: filetype:txt inurl:exploit "security vulnerability" -> Tìm tệp văn bản mô tả lỗ hổng bảo mật và khai thác.

Trang 57 (theo PDF gốc)

XÁC ĐỊNH HỆ ĐIỀU HÀNH

Kẻ tấn công dùng nhiều công cụ trực tuyến như Netcraft, Shodan và Censys để phát hiện hệ điều hành được dùng tại tổ chức mục tiêu. Các công cụ này tìm kiếm trên Internet các thiết bị được kết nối như router, server và thiết bị IoT thuộc tổ chức mục tiêu. Dùng các công cụ này, kẻ tấn công thu được các chi tiết chính như vị trí địa lý, uptime, hệ điều hành và địa chỉ IP của tổ chức mục tiêu. Thông tin đó giúp kẻ tấn công xác định các lỗ hổng tiềm năng và tìm các khai thác hiệu quả để thực hiện nhiều cuộc tấn công vào mục tiêu.

Netcraft

Nguồn: https://www.netcraft.com

Kỹ thuật thu thập thông tin về hệ điều hành của mạng mục tiêu được gọi là OS fingerprinting. Mở https://www.netcraft.com/tools/ trong trình duyệt rồi nhập URL của tổ chức mục tiêu vào trường What's that site running? Kẻ tấn công dùng công cụ Netcraft để xác định tất cả website liên quan đến miền mục tiêu cùng hệ điều hành đang chạy tại mỗi website.

Hình 2.35: Ảnh chụp màn hình Netcraft hiển thị kết quả cho Microsoft.

Trang 58 (theo PDF gốc)

Hình 2.36: Netcraft hiển thị hệ điều hành mục tiêu.

SHODAN Search Engine

Nguồn: https://www.shodan.io

Shodan là công cụ tìm kiếm máy tính kết nối Internet, tìm kiếm các thiết bị kết nối như router, server và IoT. Bạn có thể dùng Shodan để phát hiện những thiết bị nào kết nối Internet, chúng nằm ở đâu và ai đang sử dụng chúng.

Nó giúp kẻ tấn công theo dõi tất cả thiết bị trên mạng mục tiêu có thể truy cập trực tiếp từ Internet. Nó cũng cho phép tìm thiết bị dựa trên thành phố, quốc gia, latitude/longitude, hostname, hệ điều hành và địa chỉ IP. Ngoài ra, nó giúp kẻ tấn công tìm các lỗ hổng đã biết và khai thác, DOI/Metasploit, CVE, OSVDB và PacketsStorm trong một giao diện duy nhất.

Như ảnh chụp màn hình, kẻ tấn công dùng công cụ này để phát hiện nhiều thiết bị mục tiêu kết nối Internet cùng hệ điều hành đang sử dụng.

Trang 59 (theo PDF gốc)

Hình 2.37: Công cụ SHODAN hiển thị hệ điều hành mục tiêu.

Censys

Nguồn: https://censys.io

Censys giám sát hạ tầng và phát hiện các tài sản chưa biết ở bất kỳ đâu trên Internet. Nó cung cấp cái nhìn toàn diện về mọi server và thiết bị bị lộ trên Internet. Kẻ tấn công dùng công cụ này để giám sát hạ tầng mục tiêu nhằm phát hiện nhiều thiết bị kết nối Internet cùng chi tiết như hệ điều hành sử dụng, địa chỉ IP, giao thức sử dụng và vị trí địa lý.

Trang 60 (theo PDF gốc)

Hình 2.38: Ảnh chụp màn hình Censys Search Engine hiển thị hệ điều hành mục tiêu.

Trang 61 (theo PDF gốc)

THU THẬP COMPETITIVE INTELLIGENCE

Competitive intelligence gathering là quá trình xác định, thu thập, phân tích, xác minh và sử dụng thông tin về đối thủ cạnh tranh từ các nguồn tài nguyên trên Internet. Competitive intelligence có nghĩa là hiểu và học về các doanh nghiệp khác để trở thành doanh nghiệp cạnh tranh hơn. Về bản chất, đây là một quá trình không can thiệp và tinh tế để xác định và phân tích tài sản trí tuệ quan trọng của một dự án hoặc doanh nghiệp. Nó tập trung vào môi trường bên ngoài. Trong phương pháp này, các chuyên gia thu thập thông tin có trách nhiệm tìm kiếm, thu thập chi tiết và thường thu thập một cách bí mật.

Competitive intelligence giúp xác định:

- Đối thủ đang làm gì?
- Đối thủ đang định vị sản phẩm và dịch vụ như thế nào?
- Khách hàng đang nói gì về sản phẩm của đối thủ, điểm mạnh và điểm yếu?

Các công ty thực hiện competitive intelligence bằng cách thuê người tìm kiếm thông tin hoặc sử dụng dịch vụ cơ sở dữ liệu thương mại chuyên sâu. Thông tin được thu thập có thể giúp quản lý và lãnh đạo công ty đưa ra quyết định chiến lược.

Nguồn competitive intelligence trong hình gồm: website và báo cáo tuyển dụng của công ty; công cụ tìm kiếm, Internet và cơ sở dữ liệu trực tuyến; thông cáo báo chí và báo cáo thường niên; tạp chí thương mại, hội nghị và báo chí; bằng sáng chế và nhãn hiệu; social engineering nhân viên; catalog sản phẩm và cửa hàng bán lẻ; báo cáo phân tích và cơ quan quản lý; phỏng vấn khách hàng và nhà cung cấp; đại lý, nhà phân phối và nhà cung ứng.

Trang 62 (theo PDF gốc)

NGUỒN COMPETITIVE INTELLIGENCE

Competitive intelligence có thể được thu thập bằng cách tiếp cận trực tiếp hoặc gián tiếp.

Tiếp cận trực tiếp

Cách tiếp cận trực tiếp đóng vai trò là nguồn chính cho việc thu thập competitive intelligence. Kỹ thuật trực tiếp gồm thu thập thông tin từ hội chợ thương mại, social engineering nhân viên và khách hàng, v.v.

Tiếp cận gián tiếp

Thông qua cách tiếp cận gián tiếp, thông tin về đối thủ được thu thập bằng tài nguyên trực tuyến. Kỹ thuật gián tiếp gồm:

- Website công ty và báo cáo tuyển dụng.
- Chủ đề hỗ trợ và đánh giá.
- Công cụ tìm kiếm, Internet và cơ sở dữ liệu trực tuyến.
- Bài đăng mạng xã hội.
- Thông cáo báo chí và báo cáo thường niên.
- Tạp chí thương mại, hội nghị và báo chí.
- Bằng sáng chế và nhãn hiệu.
- Catalog sản phẩm và cửa hàng bán lẻ.
- Báo cáo phân tích và cơ quan quản lý.
- Phỏng vấn khách hàng và nhà cung cấp.
- Đại lý, nhà phân phối và nhà cung ứng.
- Blog và ấn phẩm chuyên ngành.
- Cơ sở dữ liệu pháp lý, ví dụ LexisNexis.
- Cơ sở dữ liệu thông tin doanh nghiệp, ví dụ D&B Hoovers.
- Tin tuyển dụng trực tuyến.
- Hồ sơ tài chính.
- Giải pháp công nghệ, ví dụ Crunchbase.
- Phân tích sở hữu trí tuệ.

Trang 63 (theo PDF gốc)

COMPETITIVE INTELLIGENCE - CÔNG TY NÀY BẮT ĐẦU KHI NÀO? PHÁT TRIỂN THẾ NÀO?

Thu thập tài liệu và hồ sơ của đối thủ giúp cải thiện năng suất và lợi nhuận, từ đó kích thích sự tăng trưởng của công ty. Nó giúp xác định câu trả lời cho các câu hỏi:

- Khi nào công ty bắt đầu? Qua competitive intelligence, công ty có thể thu thập lịch sử của một công ty cụ thể, chẳng hạn ngày thành lập. Đôi khi thu thập được thông tin quan trọng không dễ có từ nơi khác.
- Công ty phát triển như thế nào? Chiến lược khác nhau mà công ty sử dụng là gì? Development intelligence có thể bao gồm chiến lược quảng cáo, quản lý quan hệ khách hàng, v.v.
- Ai lãnh đạo? Thông tin này giúp công ty biết về những người ra quyết định của đối thủ.
- Công ty đặt ở đâu? Competitive intelligence cũng bao gồm vị trí công ty và thông tin liên quan đến nhiều chi nhánh và hoạt động.

Kẻ tấn công có thể dùng thông tin thu thập qua competitive intelligence để xây dựng chiến lược hacking.

Các trang tài nguyên thông tin giúp thu thập competitive intelligence:

EDGAR Database

Nguồn: https://www.sec.gov/edgar

Hệ thống Electronic Data Gathering, Analysis, and Retrieval (EDGAR) thực hiện thu thập, xác thực, lập chỉ mục, chấp nhận và chuyển tiếp tự động các hồ sơ do công ty và tổ chức phải nộp theo luật cho U.S. Securities and Exchange Commission (SEC). Mục tiêu chính là tăng hiệu quả và tính công bằng của thị trường chứng khoán vì lợi ích của nhà đầu tư, công ty và nền kinh tế bằng cách tăng tốc tiếp nhận, chấp nhận, phổ biến và phân tích thông tin doanh nghiệp nhạy cảm theo thời gian do cơ quan này nộp.

D&B Hoovers

Nguồn: https://www.dnb.com

D&B Hoovers tận dụng cơ sở dữ liệu thương mại có 120 triệu hồ sơ doanh nghiệp và phân tích để cung cấp giải pháp sales intelligence, giúp đội ngũ bán hàng và marketing tập trung vào khách hàng tiềm năng phù hợp để đạt tăng trưởng nhanh hơn và bền vững hơn.

Trang 64 (theo PDF gốc)

LexisNexis

Nguồn: https://www.lexisnexis.com

LexisNexis cung cấp giải pháp quy trình làm việc tập trung vào nội dung, được thiết kế đặc biệt cho chuyên gia trong lĩnh vực pháp lý, quản lý rủi ro, doanh nghiệp, chính phủ, thực thi pháp luật, kế toán và học thuật. Nó duy trì cơ sở dữ liệu điện tử về thông tin liên quan đến pháp lý và hồ sơ công khai. Nó cho phép khách hàng truy cập tài liệu và hồ sơ pháp lý và nghiệp vụ như bản án, luật, hồ sơ công khai, thông tin cá nhân, tin tức và phân tích doanh nghiệp, hỗ trợ khách hàng trong quản trị rủi ro, phòng chống gian lận, kết quả sức khỏe, giải pháp định danh, điều tra, quản lý phải thu, ra quyết định về rủi ro và tối ưu workflow.

Business Wire

Nguồn: https://www.businesswire.com

Business Wire tập trung vào phân phối thông cáo báo chí và công bố theo quy định. Công ty phân phối bản tin toàn văn, ảnh và nội dung đa phương tiện từ nhiều tổ chức trên toàn cầu đến nhà báo, phương tiện truyền thông tin tức, thị trường tài chính, nhà đầu tư, website thông tin, cơ sở dữ liệu pháp lý và tài chính. Nó được vận hành qua hội thảo, website và bản phát hành.

Factiva

Nguồn: https://www.dowjones.com

Factiva là cơ sở dữ liệu tin tức toàn cầu và nhà cung cấp nội dung được cấp phép. Đây là công cụ nghiên cứu và tìm kiếm thông tin doanh nghiệp lấy thông tin từ nguồn cấp phép và miễn phí, giúp tìm kiếm, lọc, phổ biến và quản lý thông tin. Sản phẩm Factiva cung cấp truy cập hơn 33.000 nguồn như ấn phẩm được cấp phép, website có ảnh hưởng, blog, hình ảnh và video. Tài nguyên này có thể giúp kẻ tấn công xác định mọi sự kiện theo ngày tháng, tháng và năm, gồm hơn 600 newswire được cập nhật liên tục.

COMPETITIVE INTELLIGENCE - KẾ HOẠCH CỦA CÔNG TY LÀ GÌ?

Các trang tài nguyên thông tin giúp kẻ tấn công thu thập kế hoạch kinh doanh của công ty gồm:

MarketWatch

Nguồn: https://www.marketwatch.com

MarketWatch theo dõi nhịp đập thị trường cho nhà đầu tư. Đây là đơn vị đổi mới trong tin tức kinh doanh, thông tin tài chính cá nhân, bình luận theo thời gian thực và công cụ đầu tư, dữ liệu và các báo cáo ngành, quỹ tương hỗ, cổ phiếu, video và market brief.

The Wall Street Transcript

Nguồn: https://www.twst.com

The Wall Street Transcript là một website và ấn phẩm trả phí xuất bản các báo cáo ngành. Nó thể hiện quan điểm của nhà quản lý tiền và các nhà phân tích thuộc các lĩnh vực ngành khác nhau. Trang này cũng xuất bản phỏng vấn CEO của các công ty.

Trang 65 (theo PDF gốc)

Euromonitor

Nguồn: https://www.euromonitor.com

Euromonitor cung cấp năng lực nghiên cứu chiến lược cho thị trường người tiêu dùng. Nó xuất bản báo cáo về ngành, người tiêu dùng và nhân khẩu học. Cung cấp khảo sát nghiên cứu thị trường và tập trung vào nghiên cứu tổ chức.

Experian

Nguồn: https://www.experian.com

Experian cung cấp insight về chiến lược search, affiliate, display và social marketing của đối thủ cũng như chỉ số để cải thiện kết quả chiến dịch marketing. Công cụ cho phép:

- Benchmark hiệu quả chiến lược thu hút khách hàng hiện tại.
- Xác định điều gì thúc đẩy thành công của đối thủ.
- Dùng dữ liệu lịch sử người tiêu dùng để dự đoán xu hướng tương lai và nhanh chóng phản ứng với thay đổi hành vi.
- Đo lường hiệu suất website so với ngành hoặc site cụ thể.

The Search Monitor

Nguồn: https://www.thesearchmonitor.com

The Search Monitor cung cấp competitive intelligence để giám sát hoạt động brand và trademark, affiliate compliance và đối thủ trên paid search, organic search, local search, social media, mobile và shopping engine trên toàn thế giới. Nó giúp doanh nghiệp tương tác, tìm search marketer và affiliate marketer để theo dõi ad rank, ad copy, keyword reach, click rate và CPC hàng tháng, hàng tuần và chi tiêu.

USPTO

Nguồn: https://www.uspto.gov

United States Patent and Trademark Office (USPTO) cung cấp thông tin liên quan đến đăng ký bằng sáng chế và nhãn hiệu. Nó cung cấp thông tin chung về bằng sáng chế và lựa chọn nhập bằng sáng chế và nhãn hiệu.

COMPETITIVE INTELLIGENCE - CHUYÊN GIA NÓI GÌ VỀ CÔNG TY?

Các trang tài nguyên thông tin giúp kẻ tấn công lấy ý kiến chuyên gia về công ty mục tiêu gồm:

SEMrush

Nguồn: https://www.semrush.com

SEMrush là công cụ nghiên cứu từ khóa cạnh tranh. Nó có thể cung cấp danh sách từ khóa Google và AdWords cho bất kỳ site nào, cũng như báo cáo đầy đủ trong organic và paid Google search results.

Trang 66 (theo PDF gốc)

SEMrush cho phép tiếp cận kiến thức chuyên sâu về những gì đối thủ đang quảng cáo và ngân sách được phân bổ cho các chiến thuật Internet marketing cụ thể.

ABI/INFORM Global

Nguồn: https://www.proquest.com

ABI/INFORM Global là cơ sở dữ liệu doanh nghiệp. Nó cung cấp thông tin và nghiên cứu kinh doanh mới nhất. Với ABI/INFORM Global, người dùng có thể xác định điều kiện kinh doanh, kỹ thuật quản lý, xu hướng kinh doanh, thực hành quản trị và lý thuyết, chiến lược doanh nghiệp, chiến thuật và bối cảnh cạnh tranh.

SimilarWeb

Nguồn: https://www.similarweb.com

SimilarWeb tổng hợp dữ liệu từ nhiều nguồn để ước tính lưu lượng truy cập, địa lý và nguồn giới thiệu cho website và ứng dụng di động. Nó cũng cung cấp bảng điều khiển và tiện ích mở rộng trình duyệt cho phép tinh chỉnh các nguồn dữ liệu khác bằng cách theo dõi ẩn danh hoạt động duyệt web của hàng triệu người dùng trên toàn thế giới.

SERanking

Nguồn: https://seranking.com

SERanking là công cụ phân tích đối thủ trực tuyến cung cấp cái nhìn toàn diện về động lực lưu lượng website của tổ chức mục tiêu. Công cụ còn giúp doanh nghiệp hoặc người dùng nghiên cứu website đối thủ lớn, lưu lượng từ khóa, tìm keyword mới và so sánh semantic để tìm đối thủ. Nó cho phép so sánh PPC, điểm uy tín tên miền của đối thủ với đối thủ khác và chiến lược content để nâng cao chiến lược marketing của riêng mình.

Trang 67 (theo PDF gốc)

CÁC KỸ THUẬT KHÁC ĐỂ FOOTPRINTING THÔNG QUA DỊCH VỤ NGHIÊN CỨU INTERNET

Tìm vị trí địa lý của mục tiêu

Thông tin như vị trí vật lý của một tổ chức mục tiêu đóng vai trò quan trọng trong quá trình hacking. Kẻ tấn công biết vị trí tổ chức mục tiêu có thể thử dumpster diving, surveillance, social engineering và các cuộc tấn công phi kỹ thuật khác để thu thập thêm thông tin.

Công cụ tìm vị trí địa lý

Các công cụ tìm vị trí địa lý cho phép bạn tìm và khám phá phần lớn vị trí trên Trái Đất. Chúng cung cấp thông tin về hình ảnh tòa nhà cũng như môi trường xung quanh, gồm mạng Wi-Fi. Các công cụ này cung cấp bản đồ tương tác, bản đồ phác thảo, ảnh vệ tinh và thông tin để tương tác và tạo vị trí riêng, thêm dữ liệu Maps, Apple Maps, Yaze và các thiết bị khác để cung cấp thông tin về giao thông, landmark và địa chỉ cùng thông tin liên hệ. Kẻ tấn công có thể dùng thông tin này để giành quyền truy cập trái phép vào tòa nhà, mạng có dây và không dây và hệ thống.

Kẻ tấn công có thể dùng công cụ như Google Earth, Google Maps và Wikimapia để tìm hoặc xác định lối vào tòa nhà, camera an ninh, cổng, nơi ẩn náu, điểm truy cập và các hạ tầng công cộng như điện và điện tử nhằm đo khoảng cách giữa các vật thể khác nhau, v.v.

Trang 68 (theo PDF gốc)

Google Earth

Nguồn: https://www.google.com

Kẻ tấn công dùng công cụ Google Earth để tìm vị trí chính xác của mục tiêu. Sử dụng công cụ này, kẻ tấn công có thể truy cập hình ảnh 3D thể hiện hầu hết bề mặt Trái Đất với độ phân giải cao. Chi tiết cho phép thu được street view, thông tin độ cao và thậm chí tọa độ.

Hình 2.39: Ảnh chụp màn hình Google Earth.

Thu thập thông tin từ Financial Services

Kẻ tấn công tìm kiếm quyền truy cập thông tin cá nhân hoặc tài chính thường nhắm đến dữ liệu tài chính như báo giá cổ phiếu và biểu đồ, tin tức tài chính và danh mục đầu tư. Dịch vụ tài chính như Google Finance, MSN Money, Yahoo Finance và Investing.com có thể cung cấp lượng lớn thông tin hữu ích như giá trị thị trường của cổ phiếu công ty, hồ sơ công ty, chi tiết đối thủ, tỷ giá chứng khoán, báo cáo doanh nghiệp, phát hành, báo cáo tài chính cùng tin tức và blog liên quan. Thông tin này cung cấp sự thay đổi từ dịch vụ này sang dịch vụ khác. Công ty tài chính dựa vào dịch vụ web để thực hiện giao dịch tài chính và cấp quyền truy cập cho người dùng. Kẻ tấn công có thể lấy thông tin nhạy cảm và riêng tư về doanh nghiệp tài chính bằng cách gửi email, khai thác phần mềm ngân hàng trực tuyến, phá mật khẩu, social engineering, phishing và thực hiện brute-force và phishing attack.

Trang 69 (theo PDF gốc)

Google Finance

Nguồn: https://www.google.com/finance

Dịch vụ Google Finance có các tiêu đề kinh doanh và doanh nghiệp cho nhiều tập đoàn, gồm quyết định tài chính hoặc sự kiện tin tức lớn. Thông tin cổ phiếu cũng có sẵn, cũng như biểu đồ giá cổ phiếu có đánh dấu cho sự kiện tin tức lớn và hành động doanh nghiệp. Site cũng tổng hợp Google News và Google blog search articles về từng tập đoàn.

Hình 2.40: Ảnh chụp màn hình Google Finance Service.

Thu thập thông tin từ Business Profile Sites

Tìm thông tin từ các website doanh nghiệp là bước cần thiết trong giai đoạn thu thập thông tin. Các business profile site này chứa thông tin về công ty ở một vùng cụ thể với thông tin liên hệ có thể xem bởi bất kỳ ai.

Kẻ tấn công dùng business profile site như opencorporates, Crunchbase và corporationwiki để thu thập thông tin quan trọng về tổ chức mục tiêu, như vị trí, địa chỉ, thông tin liên hệ (như số điện thoại, địa chỉ email), cơ sở dữ liệu nhân viên, tên bộ phận, loại dịch vụ cung cấp và loại ngành.

Trang 70 (theo PDF gốc)

Hình 2.41: Ảnh chụp màn hình OpenCorporates hiển thị kết quả tìm kiếm Microsoft.

Giám sát mục tiêu bằng Alerts

Alerts là dịch vụ giám sát nội dung trực tuyến cung cấp thông tin tự động, cập nhật về một chủ đề hoặc mục tiêu cụ thể, thường qua email hoặc SMS. Để nhận cảnh báo, người dùng chèn truy vấn tìm kiếm trong một trường và cung cấp địa chỉ email hoặc số điện thoại. Các dịch vụ cảnh báo trực tuyến tự động thông báo khi có nội dung mới từ tin tức, blog và nhóm thảo luận khớp với tập từ khóa hoặc cụm từ do người dùng nhập. Các dịch vụ này cung cấp dữ liệu cập nhật về đối thủ và ngành.

Công cụ như Google Alerts, X Alerts và Giga Alerts giúp kẻ tấn công theo dõi đề cập về tên tổ chức, tên thành viên, website hoặc bất kỳ người hoặc dự án quan trọng nào. Kẻ tấn công có thể thu thập thông tin cập nhật về mục tiêu định kỳ từ dịch vụ cảnh báo và dùng cho các cuộc tấn công tiếp theo.

Trang 71 (theo PDF gốc)

Google Alerts

Nguồn: https://www.google.com/alerts

Google Alerts tự động thông báo cho người dùng khi nội dung mới từ tin tức, website, blog, video và/hoặc nhóm thảo luận khớp với tập từ khóa do người dùng chọn và lưu trên dịch vụ Google Alerts.

Hình 2.42: Ảnh chụp màn hình Google Alert.

Hình 2.43: Ảnh chụp màn hình Google Alert Preview.

Trang 72 (theo PDF gốc)

THEO DÕI DANH TIẾNG TRỰC TUYẾN CỦA MỤC TIÊU

Online Reputation Management (ORM) là quá trình giám sát những gì hiển thị khi ai đó tìm tên công ty hoặc danh tiếng trên Internet. ORM sau đó thực hiện các biện pháp để giảm nội dung tiêu cực và quảng bá nội dung tích cực. Quá trình giúp cải thiện danh tiếng thương hiệu.

Các công ty thường theo dõi phản hồi công chúng dành cho họ bằng công cụ ORM tracking và thực hiện biện pháp cải thiện độ tin cậy và giữ khách hàng. Đối với quản lý danh tiếng trực tuyến tích cực, tổ chức thường cố gắng minh bạch hơn trên Internet. Sự minh bạch này có thể giúp kẻ tấn công thu thập thông tin xác thực về tổ chức mục tiêu.

Công cụ Online Reputation Tracking

Công cụ theo dõi danh tiếng trực tuyến giúp phát hiện mọi người đang nói gì trực tuyến về công ty, thương hiệu theo thời gian thực trên web, mạng xã hội và tin tức. Chúng giúp giám sát, đo lường và quản lý danh tiếng trực tuyến. Kẻ tấn công có thể dùng công cụ như Mention, ReviewPush và Repupology để theo dõi danh tiếng trực tuyến của công ty.

Kẻ tấn công có thể dùng công cụ ORM tracking để:

- Theo dõi danh tiếng trực tuyến của công ty.
- Thu thập thông tin xếp hạng công cụ tìm kiếm của công ty.
- Thu được email thông báo khi tên công ty được nhắc trực tuyến.
- Theo dõi cuộc trò chuyện.
- Thu thập tin tức xã hội về tổ chức mục tiêu.

Mention

Nguồn: https://mention.com

Mention là công cụ theo dõi danh tiếng trực tuyến giúp kẻ tấn công giám sát web, social media, forum và blog để biết thêm về thương hiệu mục tiêu và ngành. Công cụ giúp theo dõi các cuộc hội thoại trực tuyến khi chúng diễn ra, ở bất kỳ đâu. Sử dụng Mention, kẻ tấn công có thể có báo cáo trực tiếp, cập nhật theo thời gian thực được gửi qua email để phân tích chi tiết theo thời gian thực.

Trang 73 (theo PDF gốc)

Hình 2.44: Ảnh chụp màn hình Mention.

Thu thập thông tin từ Groups, Forums và Blogs

Nhiều người dùng Internet dùng blog, group và forum cho mục đích chia sẻ kiến thức. Vì vậy, kẻ tấn công thường tập trung vào group, forum và blog để tìm thông tin về tổ chức mục tiêu và con người của tổ chức. Các tổ chức thường không giám sát việc trao đổi thông tin diễn ra liên quan đến người dùng trong forum, blog và group discussion. Kẻ tấn công xem đây là lợi thế và thu thập thông tin về mục tiêu như thông tin mạng công khai, thông tin hệ thống và thông tin cá nhân. Kẻ tấn công có thể đăng ký giả trên Google Groups, LinkedIn Groups, v.v. và cố gắng tham gia thảo luận nhân viên công ty mục tiêu để thu thập thông tin có giá trị về công ty và thậm chí tìm thông tin trong group, forum và blog qua Fully Qualified Domain Names (FQDNs), địa chỉ IP và username.

Thông tin nhân viên mà kẻ tấn công có thể thu thập từ group, forum và blog có thể gồm:

- Họ tên đầy đủ của nhân viên.
- Nơi làm việc và nơi cư trú.
- Số điện thoại nhà, số di động hoặc số văn phòng.
- Địa chỉ email cá nhân và email tổ chức.
- Ảnh nơi ở hoặc nơi làm việc của nhân viên có chứa thông tin có thể nhận diện.
- Ảnh giải thưởng nhân viên và phần thưởng hoặc mục tiêu sắp tới.

Trang 74 (theo PDF gốc)

Hình 2.45: Ảnh chụp màn hình Google Groups.

Thu thập thông tin từ Public Source-Code Repositories

Source code-based repositories là dịch vụ trực tuyến hoặc công cụ có sẵn trên máy chủ nội bộ hoặc có thể được lưu trên website bên thứ ba như GitHub, GitLab, SourceForge và BitBucket. Những site này chứa dữ liệu nhạy cảm liên quan đến tệp cấu hình, private Secure Shell (SSH) và source code. Tệp script, khóa, source-code file, dynamic library và software tool do developer đăng có thể bị hacker tìm kiếm và tấn công nhằm thực hiện các cuộc tấn công vào tổ chức mục tiêu.

Chuyên gia phần mềm lưu trữ lượng lớn source code liên quan trang web và chương trình tại public repository hoặc private repository. Để đáp ứng deadline và tăng hiệu suất trong quá trình phát triển sản phẩm, developer có thể truy cập dữ liệu lưu trong repository để phát triển hoặc vá ứng dụng nhanh chóng và giảm thời gian phát triển cũng như chi phí.

Website source-code repository như GitHub có thể chứa các lỗi bảo mật mở đường cho kẻ tấn công nhắm vào ứng dụng. Ứng dụng được đăng trên website công khai có thể chứa thông tin bí mật của tổ chức mục tiêu mà kẻ tấn công có thể tìm kiếm và xác định developer và công nghệ được dùng.

Trang 75 (theo PDF gốc)

Thông tin thu thập từ public repository có thể chưa đủ để thực hiện tấn công trực tiếp, nhưng khi kết hợp với một số kỹ thuật footprinting chủ động như spear-phishing nhắm vào người dùng hoặc nhân viên cụ thể của tổ chức mục tiêu, nó có thể giúp ích. Ngoài ra, các lỗi bảo mật trong repository cũng có thể hỗ trợ kẻ tấn công tích lũy tấn công social engineering và hạ tầng vào tổ chức mục tiêu.

Kẻ tấn công có thể dùng công cụ như Recon-ng để khám phá public source-code repository.

Recon-ng

Nguồn: https://github.com

Recon-ng là một reconnaissance framework đầy đủ tính năng được thiết kế để cung cấp môi trường mạnh mẽ nhằm thực hiện web-based reconnaissance nhanh chóng và toàn diện. Nó hỗ trợ kẻ tấn công thu thập thông tin từ public source-code repository.

Hình 2.46: Ảnh chụp màn hình recon-ng hiển thị việc tạo workspace và tìm marketplace.

Trang 76 (theo PDF gốc)

Hình 2.47: Ảnh chụp màn hình recon-ng hiển thị source-code repositories.

Trang 77 (theo PDF gốc)

Mục tiêu 04: Minh họa Footprinting thông qua các trang mạng xã hội

Reconnaissance thụ động

FOOTPRINTING THÔNG QUA SOCIAL NETWORKING SITES

Trong khi footprinting qua social networking site có vẻ tương tự footprinting qua social engineering, vốn được thảo luận ở mức chi tiết khác, có một số khác biệt giữa hai phương pháp. Trong footprinting bằng social engineering, kẻ tấn công lừa người khác tiết lộ thông tin; còn trong footprinting qua social networking site, kẻ tấn công thu thập thông tin có sẵn trên các site này. Kẻ tấn công thậm chí có thể dùng social networking site như một phương tiện để thực hiện social engineering attack.

Phần này giải thích loại thông tin có thể thu thập từ social networking site và cách có thể thu được, nhằm giúp bạn xác định thông tin từ các social media site bằng nhiều dịch vụ và tài nguyên trực tuyến.

Tìm người trên Social Networking Sites

Tìm kiếm một người hoặc tổ chức cụ thể trên website social networking khá dễ. Dịch vụ mạng xã hội là dịch vụ trực tuyến, nền tảng hoặc site tập trung tạo mạng xã hội hoặc quan hệ giữa người với người. Những website này chứa thông tin do người dùng cung cấp trong hồ sơ. Thông tin thường được thay đổi thông qua nhiều trường, như sở thích chung, vị trí công việc và giáo dục.

Các social networking site cho phép mọi người chia sẻ thông tin nhanh chóng vì họ có thể cập nhật chi tiết cá nhân theo thời gian thực. Những site này cho phép người dùng cập nhật sự kiện quá khứ, hiện tại và tương lai, thông báo và lời mời. Social networking site là nền tảng tuyệt vời để tìm người và thông tin liên quan. Nhiều site mạng xã hội cho phép khách truy cập tìm người mà không cần đăng ký. Trong một số trường hợp, người tìm kiếm có thể chỉ dùng username, email hoặc địa chỉ để tìm người.

Trang 78 (theo PDF gốc)

Một số site cho phép người dùng kiểm tra xem tài khoản có đang hoạt động hay không, từ đó cung cấp thông tin về trạng thái của người được tìm kiếm.

Các social networking site như Facebook, Twitter, LinkedIn và Instagram cho phép tìm người theo tên, từ khóa, công ty, trường học, bạn bè, đồng nghiệp và những người sống xung quanh. Tìm kiếm người cung cấp kết quả về thông tin cá nhân như tên, vị trí hiện tại và trình độ học vấn. Ngoài ra, bạn cũng có thể tìm thông tin nghề nghiệp như công ty hoặc doanh nghiệp, vị trí hiện tại, số điện thoại, email, ID ảnh, video và v.v. Mạng xã hội như Twitter được dùng để chia sẻ lời khuyên, tin tức, mối quan tâm, ý kiến, tin đồn và sự thật. Thông qua việc tìm kiếm người trên social networking service, kẻ tấn công có thể thu thập thông tin quan trọng giúp thực hiện social engineering hoặc các kiểu tấn công khác.

Hình 2.48: Ảnh chụp màn hình Facebook hiển thị kết quả tìm kiếm.

Trang 79 (theo PDF gốc)

THU THẬP THÔNG TIN TỪ LINKEDIN

Kẻ tấn công dùng theHarvester để thực hiện enumeration trên LinkedIn và tìm nhân viên của công ty mục tiêu cùng chức danh công việc. Kẻ tấn công có thể dùng thông tin này để thu thập thêm thông tin như chi tiết vị trí, trình độ học vấn và thực hiện social engineering hoặc các cuộc tấn công khác.

LinkedIn là website mạng xã hội dành cho chuyên gia. Nó kết nối nhân lực, nguồn lực và năng suất của thế giới. Site chứa thông tin cá nhân như tên, vị trí, tên tổ chức, vị trí hiện tại, trình độ học vấn, v.v. Thông tin thu thập từ LinkedIn giúp kẻ tấn công thực hiện social engineering hoặc các kiểu tấn công khác.

Kẻ tấn công có thể dùng công cụ theHarvester để thu thập thông tin từ LinkedIn dựa trên tên tổ chức mục tiêu.

theHarvester

Nguồn: https://github.com

TheHarvester là công cụ được thiết kế để dùng trong giai đoạn đầu của penetration test. Nó được dùng để thu thập thông tin giúp xác định external threat landscape của công ty. Kẻ tấn công dùng công cụ này để thực hiện enumeration trên LinkedIn social networking site để tìm nhân viên của công ty mục tiêu cùng chức danh công việc.

Lệnh ví dụ:

```
theHarvester -d microsoft -l 200 -b linkedin
```

Trong lệnh trên, -d chỉ định miền hoặc tên công ty cần tìm, -l chỉ định số kết quả, -b chỉ định nguồn dữ liệu là LinkedIn.

Trang 80 (theo PDF gốc)

Hình 2.49: Ảnh chụp màn hình lệnh theHarvester để enumerate người dùng trên LinkedIn.

Hình 2.50: Ảnh chụp màn hình kết quả tìm kiếm LinkedIn của theHarvester, lấy thông tin về nhân viên mục tiêu như tên, chức danh, v.v.

Trang 81 (theo PDF gốc)

THU THẬP DANH SÁCH EMAIL VỚI AI

Kẻ tấn công sử dụng các công cụ tự động như theHarvester và Email Spider để thu thập các địa chỉ email công khai của nhân viên trong tổ chức mục tiêu. Các công cụ này thu thập email liên quan đến một miền cụ thể bằng công cụ tìm kiếm như Google, Bing và Yahoo. Kẻ tấn công sử dụng các danh sách email này và username để thực hiện social engineering và các cuộc tấn công brute-force vào tổ chức mục tiêu.

Thu thập danh sách email

Việc thu thập địa chỉ email liên quan đến tổ chức mục tiêu là một vector tấn công quan trọng trong giai đoạn cuối. Kẻ tấn công có thể sử dụng các công cụ tự động như theHarvester và Email Spider để thu thập địa chỉ email có sẵn công khai của nhân viên thuộc tổ chức mục tiêu. Các công cụ này thu thập email liên quan đến một miền cụ thể bằng công cụ tìm kiếm như Google, Bing và Yahoo. Kẻ tấn công sử dụng các danh sách email và username này để thực hiện social engineering và các cuộc tấn công brute-force vào tổ chức mục tiêu.

TheHarvester

Nguồn: https://github.com

Kẻ tấn công sử dụng theHarvester để trích xuất các địa chỉ email liên quan đến miền mục tiêu. Ví dụ, để thu thập các địa chỉ email của microsoft.com bằng công cụ tìm kiếm Baidu, dùng lệnh:

```
theHarvester -d microsoft.com -l 200 -b baidu
```

Trong lệnh trên, -d chỉ định miền mục tiêu, -l giới hạn kết quả ở 200 và -b chỉ định nguồn dữ liệu Baidu. Có thể dùng Google, Bing, v.v. thay thế.

Trang 82 (theo PDF gốc)

Hình 2.51: Ảnh chụp màn hình lệnh theHarvester để trích xuất địa chỉ email.

Hình 2.52: Ảnh chụp màn hình danh sách email được theHarvester trích xuất.

Trang 83 (theo PDF gốc)

THU THẬP DANH SÁCH EMAIL VỚI AI

Kẻ tấn công có thể tận dụng công nghệ hỗ trợ AI để nâng cao và tự động hóa các tác vụ footprinting. Với sự trợ giúp của AI, kẻ tấn công có thể dễ dàng tìm các chi tiết email có giá trị của tổ chức mục tiêu.

Ví dụ, kẻ tấn công có thể dùng ChatGPT bằng prompt phù hợp:

“Use theHarvester to gather email accounts associated with 'microsoft.com', limiting results to 200, and leveraging 'baidu' as a data source”

(Dùng theHarvester để thu thập các tài khoản email liên quan đến microsoft.com, giới hạn kết quả ở 200 và dùng Baidu làm nguồn dữ liệu.)

Hình 2.53: Dùng theHarvester để thu thập các tài khoản email liên quan đến microsoft.com.

Để thu thập tài khoản email liên quan đến microsoft.com bằng theHarvester, giới hạn kết quả ở 200 và dùng Baidu làm nguồn dữ liệu, có thể dùng lệnh:

```
theHarvester -d microsoft.com -l 200 -b Baidu -F Microsoft_emails.xml
```

Giải thích:

- theHarvester: lệnh gọi công cụ theHarvester.
- -d microsoft.com: chỉ định miền mục tiêu.
- -l 200: giới hạn số kết quả ở 200.
- -b Baidu: chỉ định “baidu” làm nguồn dữ liệu để thu thập các tài khoản email liên quan đến microsoft.com.

Trang 84 (theo PDF gốc)

- -F Microsoft_emails.xml: chỉ định tệp đầu ra nơi lưu các tài khoản email. Trong trường hợp này, tệp được đặt tên Microsoft_emails.xml và các tài khoản email được lưu ở định dạng XML.

Hình 2.54: Thu thập tài khoản email liên quan đến microsoft.com bằng theHarvester.

Trang 85 (theo PDF gốc)

PHÂN TÍCH SỰ HIỆN DIỆN CỦA MỤC TIÊU TRÊN MẠNG XÃ HỘI

Một số dịch vụ trực tuyến và tài nguyên có sẵn để thu thập thông tin có giá trị về mục tiêu từ một hoặc nhiều social media site. Các dịch vụ này cho phép kẻ tấn công khám phá nội dung được chia sẻ nhiều nhất trên các social media site bằng hashtag hoặc từ khóa, theo dõi tài khoản và URL trên nhiều site, lấy địa chỉ email của mục tiêu, v.v. Thông tin này giúp kẻ tấn công thực hiện phishing, social engineering và các kiểu tấn công khác.

Kẻ tấn công sử dụng các công cụ như BuzzSumo, Google Trends, Hashatit và Ubersuggest để xác định thông tin trên social media site.

BuzzSumo

Nguồn: https://buzzsumo.com

Công cụ tìm kiếm xã hội nâng cao của BuzzSumo tìm nội dung được chia sẻ nhiều nhất cho một chủ đề, tác giả hoặc miền. Nó hiển thị hoạt động chia sẻ trên tất cả các mạng xã hội lớn gồm Twitter, Facebook, LinkedIn, Google Plus và Pinterest.

Như trong ảnh chụp màn hình, kẻ tấn công dùng BuzzSumo để theo dõi nội dung được chia sẻ nhiều nhất liên quan đến tổ chức mục tiêu và thu thập chi tiết như ID tài khoản mạng xã hội, URL và địa chỉ email.

Trang 86 (theo PDF gốc)

Hình 2.55: Ảnh chụp màn hình BuzzSumo hiển thị nội dung được chia sẻ.

Trang 87 (theo PDF gốc)

CÁC CÔNG CỤ FOOTPRINTING THÔNG QUA SOCIAL NETWORKING SITES

Kẻ tấn công dùng nhiều công cụ như Sherlock và Social Searcher để footprinting social networking site như Twitter, Instagram, Facebook và Pinterest nhằm thu thập thông tin nhạy cảm về mục tiêu như ngày sinh, trình độ học vấn, tình trạng việc làm, tên người thân và thông tin về tổ chức mà họ đang làm việc, gồm địa chỉ doanh nghiệp, khách hàng tiềm năng và dự án/sản phẩm sắp tới.

Sherlock

Nguồn: https://github.com

Như trong ảnh chụp màn hình, kẻ tấn công dùng Sherlock để tìm kiếm một lượng lớn social networking site cho một username mục tiêu. Công cụ này giúp kẻ tấn công xác định vị trí người dùng mục tiêu trên nhiều social networking site, cùng với URL hồ sơ đầy đủ.

Trang 88 (theo PDF gốc)

Hình 2.56: Ảnh chụp màn hình kết quả của công cụ Sherlock.

Social Searcher

Nguồn: https://www.social-searcher.com

Social Searcher cho phép kẻ tấn công tìm kiếm nội dung trên các mạng xã hội theo thời gian thực và cung cấp phân tích dữ liệu sâu. Kẻ tấn công dùng công cụ này để theo dõi người dùng mục tiêu trên nhiều social networking site và thu thập thông tin như URL đầy đủ đến hồ sơ, bài đăng và thông tin cá nhân khác.

Trang 89 (theo PDF gốc)

Hình 2.57: Ảnh chụp màn hình Social Searcher hiển thị nội dung người dùng trên mạng xã hội.

Trang 90 (theo PDF gốc)

FOOTPRINTING THÔNG QUA SOCIAL NETWORKING SITES VỚI AI

Kẻ tấn công có thể tận dụng công nghệ hỗ trợ AI để nâng cao và tự động hóa tác vụ footprinting. Với sự trợ giúp của AI, kẻ tấn công có thể dễ dàng dùng các công cụ social networking site để thu thập thông tin có giá trị về mục tiêu.

Ví dụ, kẻ tấn công có thể dùng ChatGPT bằng prompt phù hợp:

“Use Sherlock to gather personal information about Sundar Pichai and save the result in recon2.txt”

(Dùng Sherlock để thu thập thông tin cá nhân về Sundar Pichai và lưu kết quả vào recon2.txt.)

Hình 2.58: Tìm các tài khoản trực tuyến liên quan đến tên “Sundar Pichai”.

Trang 91 (theo PDF gốc)

Để tìm các tài khoản trực tuyến liên quan đến tên “Sundar Pichai” bằng Sherlock và lưu đầu ra vào tệp “recon2”, có thể dùng lệnh:

sherlock SundarPichai --output recon2

Giải thích:

- sherlock: lệnh chạy Sherlock, công cụ tìm kiếm tài khoản trực tuyến trên nhiều nền tảng.
- SundarPichai: tên cần tìm tài khoản trực tuyến.
- --output recon2: chỉ định tệp đầu ra để lưu kết quả, ở đây là recon2.

Hình 2.59: Tệp đầu ra.

Trang 92 (theo PDF gốc)

Mục tiêu 05: Sử dụng các kỹ thuật khác nhau cho Whois Footprinting

Reconnaissance thụ động

WHOIS FOOTPRINTING

Việc thu thập thông tin liên quan đến mạng như thông tin “Whois” về tổ chức mục tiêu là quan trọng khi lập kế hoạch tấn công. Trong phần này, chúng ta sẽ thảo luận Whois footprinting, giúp thu thập thông tin miền như thông tin về chủ sở hữu tổ chức, chi tiết đăng ký, tên, server và thông tin liên hệ. Whois footprinting tập trung vào cách thực hiện Whois lookup, phân tích kết quả Whois, tìm thông tin IP geolocation và các công cụ dùng để thu thập thông tin Whois.

Trang 93 (theo PDF gốc)

WHOIS LOOKUP

Whois database được duy trì bởi Regional Internet Registries và chứa thông tin cá nhân của chủ sở hữu miền.

Truy vấn Whois có thể trả về:

- Chi tiết tên miền.
- Chi tiết liên hệ của chủ sở hữu miền.
- Name server miền.
- NetRange.
- Thời điểm miền được tạo.
- Bản ghi hết hạn.
- Bản ghi cập nhật gần nhất.

Thông tin thu được từ Whois database giúp kẻ tấn công:

- Thu thập thông tin cá nhân để hỗ trợ social engineering.
- Tạo bản đồ mạng của tổ chức mục tiêu.
- Thu thập chi tiết nội bộ của tổ chức mục tiêu.

Regional Internet Registries (RIRs) được minh họa gồm ARIN, RIPE NCC, LACNIC, APNIC và AFRINIC.

Whois Lookup (tiếp)

Whois là giao thức truy vấn-phản hồi dùng để truy vấn cơ sở dữ liệu lưu người dùng hoặc người được cấp tài nguyên Internet, chẳng hạn tên miền, khối địa chỉ IP hoặc autonomous system. Giao thức này nghe trên cổng TCP 43. Regional Internet Registries (RIRs) duy trì Whois database chứa thông tin cá nhân của chủ sở hữu miền. Đối với mỗi tài nguyên, Whois database cung cấp bản ghi văn bản với thông tin về tài nguyên đó.

Trang 94 (theo PDF gốc)

Bản ghi Whois cung cấp thông tin về chính tài nguyên cũng như thông tin liên quan về assignee, registrant và thông tin quản trị (ngày tạo và hết hạn).

Ba mô hình dữ liệu để lưu và tra cứu thông tin Whois:

- Thick Whois (Distributed Model): Lưu toàn bộ thông tin Whois từ tất cả registrar cho một tập dữ liệu cụ thể.
- Thin Whois (Centralized Model): Chỉ lưu tên máy chủ Whois của registrar của một miền; bản ghi này chứa đầy đủ thông tin về tên miền đang được tra cứu.
- Decentralized Whois: Lưu toàn bộ thông tin WHOIS và có nhiều thực thể độc lập quản lý Whois database.

Truy vấn Whois thường trả về:

- Chi tiết tên miền.
- Registrar của miền.
- Chi tiết liên hệ chủ sở hữu miền.
- Name server miền.
- NetRange.
- Thời điểm miền được tạo.
- Bản ghi hết hạn.
- Bản ghi cập nhật gần nhất.
- Trạng thái miền (available, registered hoặc suspended).
- Thông tin địa chỉ IP.

Kẻ tấn công có thể truy vấn máy chủ Whois database để thu thập thông tin về miền mục tiêu và sau đó lấy phản hồi Whois cho truy vấn. Dùng thông tin này, kẻ tấn công có thể tạo bản đồ mạng của tổ chức, đánh lừa chủ sở hữu miền bằng social engineering và thu thập chi tiết nội bộ của mạng.

Regional Internet Registries (RIRs):

- American Registry for Internet Numbers (ARIN): https://www.arin.net
- African Network Information Center (AFRINIC): https://www.afrinic.net
- Asia Pacific Network Information Center (APNIC): https://www.apnic.net
- Réseaux IP Européens Network Coordination Centre (RIPE): https://www.ripe.net
- Latin American and Caribbean Network Information Center (LACNIC): https://www.lacnic.net

Trang 95 (theo PDF gốc)

KẾT QUẢ WHOIS LOOKUP

Các dịch vụ Whois như https://whois.domaintools.com và https://www.tamos.com có thể giúp thực hiện Whois lookup. Ảnh chụp màn hình minh họa kết quả Whois lookup thu được bằng công cụ whois cho một tên miền hoặc website cụ thể. Dịch vụ cung cấp IP country, IP address, hostname hoặc domain, gồm thông tin về country, state/province, city, phone number, fax number, owner, network provider, administrator và technical-support contact. Nó hỗ trợ Internationalized Domain Names (IDNs), tức có thể truy vấn tên miền sử dụng ký tự không phải tiếng Anh. Nó cũng hỗ trợ địa chỉ IPv6.

Hình 2.60: Ảnh chụp màn hình Whois.

Trang 96 (theo PDF gốc)

Hình 2.61: Ảnh chụp màn hình Batch IP Converter.

Kẻ tấn công cũng dùng các công cụ Whois lookup như WHOIS Domain Lookup và Active Whois để thực hiện Whois lookup trên miền mục tiêu.

Trang 97 (theo PDF gốc)

TÌM THÔNG TIN ĐỊNH VỊ IP (IP GEOLOCATION)

IP geolocation giúp thu thập thông tin về mục tiêu như quốc gia, vùng/bang, thành phố, vĩ độ và kinh độ của thành phố, mã ZIP/bưu chính, múi giờ, tốc độ kết nối, ISP (công ty hosting), tên miền, mã quốc gia IDD, mã vùng, tên và mã trạm thời tiết, nhà mạng di động và độ cao.

Dùng thông tin thu được từ IP geolocation, kẻ tấn công có thể cố gắng thu thập thêm thông tin về mục tiêu với sự trợ giúp của social engineering, surveillance và các cuộc tấn công phi kỹ thuật như dumpster diving, hoaxing hoặc đóng vai một chuyên gia. Với sự trợ giúp của thông tin thu được, kẻ tấn công cũng có thể thiết lập command shell trên vị trí của nạn nhân; nếu phát hiện chính xác vị trí nạn nhân, kẻ tấn công có thể thực hiện hoạt động độc hại và lây nhiễm thiết bị nạn nhân bằng malware được thiết kế cho khu vực đó hoặc truy cập trái phép mạng của mục tiêu hoặc cố gắng phát động cuộc tấn công vào thiết bị mục tiêu.

Các công cụ IP geolocation lookup như IP2Location, IP Location Finder và IP Address Geographical Location Finder giúp thu thập thông tin IP geolocation về mục tiêu, cho phép kẻ tấn công phát động social engineering attack như spamming và phishing.

Công cụ IP Geolocation Lookup

IP2Location

Nguồn: https://www.ip2location.com

Như trong ảnh chụp màn hình, kẻ tấn công dùng công cụ IP2Location để xác định vị trí địa lý của người truy cập, tức quốc gia, vùng, thành phố, vĩ độ và kinh độ, mã ZIP, múi giờ, tốc độ kết nối, ISP, tên miền, mã IDD quốc gia, mã vùng, mã và tên trạm thời tiết, nhà mạng di động, độ cao và thông tin loại sử dụng bằng cơ sở dữ liệu proprietary IP address lookup và công nghệ IP.

Trang 98 (theo PDF gốc)

Hình 2.62: Ảnh chụp màn hình IP2Location với các trường dữ liệu geolocation như IP address, country, region, city, ISP, latitude, longitude, ZIP code, time zone, weather station, mobile carrier, v.v.

Trang 99 (theo PDF gốc)

Mục tiêu 06: Sử dụng các kỹ thuật khác nhau cho DNS Footprinting

Reconnaissance chủ động

DNS FOOTPRINTING

Sau khi thu thập các bản ghi Whois của mục tiêu, giai đoạn tiếp theo của phương pháp footprinting là Domain Name System (DNS) footprinting. Kẻ tấn công thực hiện DNS footprinting để thu thập thông tin về DNS server, DNS record và loại server được tổ chức mục tiêu sử dụng. Thông tin này giúp kẻ tấn công xác định host kết nối trong mạng mục tiêu và thu thập thêm thông tin tổ chức. Phần này mô tả cách trích xuất thông tin DNS và thực hiện reverse DNS lookup bằng nhiều công cụ DNS interrogation.

Trang 100 (theo PDF gốc)

TRÍCH XUẤT THÔNG TIN DNS

DNS footprinting tiết lộ thông tin về dữ liệu DNS zone. Dữ liệu DNS zone gồm tên miền DNS, thông tin chủ sở hữu máy tính, địa chỉ IP và tên miền cùng mạng.

Kẻ tấn công sử dụng thông tin DNS để xác định các host quan trọng trong mạng rồi thực hiện social engineering attack nhằm thu thập thêm thông tin.

Các loại bản ghi DNS quan trọng:

- A: Trỏ tới địa chỉ IPv4 của host.
- AAAA: Trỏ tới địa chỉ IPv6 của host.
- MX: Trỏ tới mail server của miền.
- NS: Trỏ tới name server của miền.
- CNAME: Canonical naming cho phép alias tới một host.
- SOA: Cho biết authority của miền.
- SRV: Service record.
- PTR: Ánh xạ địa chỉ IP tới hostname.
- RP: Responsible person.
- HINFO: Thông tin host gồm loại CPU và OS.
- TXT: Bản ghi văn bản không có cấu trúc.

Bảng 2.4: Các bản ghi DNS và mô tả.

Trang 101 (theo PDF gốc)

CÔNG CỤ DNS INTERROGATION

Kẻ tấn công dùng các công cụ DNS interrogation như SecurityTrails, Fierce, DNSChecker, zdns và DNSdumpster.com để thực hiện DNS footprinting. Các công cụ này có thể trích xuất một dải địa chỉ IP cho một miền cụ thể. Nếu tổ chức mục tiêu không duy trì DNS zone data trên server riêng, dữ liệu này sẽ được chuyển sang công cụ DNS interrogation của bên thứ ba.

Khi kẻ tấn công truy vấn DNS server bằng công cụ DNS interrogation, server phản hồi bằng bản ghi cho biết thông tin về DNS mục tiêu. DNS record cung cấp thông tin quan trọng về vị trí và loại server.

SecurityTrails

Nguồn: https://securitytrails.com

SecurityTrails là công cụ DNS enumeration nâng cao có khả năng tạo bản đồ DNS của miền mục tiêu. Nó có thể enumerate cả DNS record hiện tại và lịch sử như A, AAAA, NS, MX, SOA và TXT, giúp xây dựng cấu trúc DNS. Nó cũng enumerate tất cả subdomain của miền mục tiêu bằng kỹ thuật brute-force.

Hình 2.63: Ảnh chụp màn hình SecurityTrails.

Trang 102 (theo PDF gốc)

Fierce

Nguồn: https://github.com

Fierce là công cụ DNS reconnaissance dùng để quét và thu thập thông tin quan trọng về miền mục tiêu. Kẻ tấn công có thể dùng công cụ này để enumerate subdomain liên quan đến miền mục tiêu. Nó cũng cho phép xác định các khoảng IP không liên tiếp và hostname được liên kết với IP hoặc subdomain cụ thể. Bằng cách thu thập thông tin này, kẻ tấn công có thể khám phá môi trường mạng mục tiêu và xác định các mục tiêu để khai thác.

Các lệnh ví dụ để DNS reconnaissance với Fierce:

- Quét cơ bản miền mục tiêu certifiedhacker.com, không có tùy chọn bổ sung:

```
fierce --domain certifiedhacker.com
```

Hình 2.64: Quét DNS reconnaissance miền mục tiêu.

- Quét miền mục tiêu để lấy các subdomain cụ thể như here, subdomains chứa từ như admin và mail:

```
fierce --domain certifiedhacker.com --subdomains write admin mail
```

Hình 2.65: Quét đơn giản trên miền mục tiêu.

Trang 103 (theo PDF gốc)

- Quét các miền gần với các bản ghi đã phát hiện:

```
fierce --domain certifiedhacker.com --subdomains mail --traverse 10
```

Trong lệnh trên, tùy chọn --traverse 10 yêu cầu Fierce tìm các khối IP liền kề trong phạm vi 10.

Hình 2.66: Quét miền gần các bản ghi được phát hiện.

- Tìm tất cả miền liên kết tới HTTP trên các miền đã phát hiện:

```
fierce --domain certifiedhacker.com --subdomains mail --connect
```

Trang 104 (theo PDF gốc)

Hình 2.67: Hiển thị kết nối HTTP trên các miền được phát hiện.

- Quét tất cả bản ghi đã phát hiện của miền mục tiêu, tức một bản quét đầy đủ:

```
fierce --domain certifiedhacker.com --wide
```

Hình 2.68: Quét các bản ghi đã phát hiện thuộc mọi lớp.

Trang 105 (theo PDF gốc)

DNS LOOKUP VỚI AI

Kẻ tấn công có thể tận dụng công nghệ hỗ trợ AI để nâng cao và tự động hóa tác vụ footprinting. Với sự trợ giúp của AI, kẻ tấn công có thể dễ dàng thực hiện hoạt động reverse DNS lookup trên mục tiêu và thu thập insight có giá trị.

Ví dụ, kẻ tấn công có thể dùng ChatGPT bằng prompt phù hợp:

“Install and use DNSRecon to perform DNS enumeration on the target domain www.certifiedhacker.com”

(Cài đặt và dùng DNSRecon để thực hiện DNS enumeration trên miền mục tiêu www.certifiedhacker.com.)

Hình 2.69: Prompt cài đặt và thực hiện DNSRecon với AI.

Trang 106 (theo PDF gốc)

Lệnh shell sau được thiết kế để thực hiện DNS enumeration bằng công cụ “dnsrecon” trên miền www.certifiedhacker.com:

```
sudo apt-get update && sudo apt-get install -y dnsrecon && dnsrecon -d certifiedhacker.com -t std
```

Giải thích:

- sudo apt-get update: cập nhật danh sách package để nâng cấp và cài đặt package mới.
- &&: nối các lệnh để thực thi tuần tự.
- sudo apt-get install -y dnsrecon: cài dnsrecon với tùy chọn tự động trả lời “yes” cho mọi prompt.
- dnsrecon -d certifiedhacker.com -t std: chạy dnsrecon để thực hiện DNS enumeration trên miền certifiedhacker.com bằng kỹ thuật enumeration chuẩn.

Hình 2.70: Đầu ra thực hiện DNSRecon với AI.

Trang 107 (theo PDF gốc)

REVERSE DNS LOOKUP

Kẻ tấn công thực hiện reverse DNS lookup trên dải IP nhằm xác định bản ghi DNS PTR cho các địa chỉ IP đó. Kẻ tấn công dùng nhiều công cụ như DNSRecon và Reverse Lookup để thực hiện reverse DNS lookup trên dải mục tiêu.

DNS lookup dùng để tìm địa chỉ IP cho một tên miền cho trước, còn reverse DNS dùng để thực hiện DNS lookup ngược, tức xác định tên miền từ địa chỉ IP. Khi tìm kiếm miền bằng cách nhập tên miền vào trình duyệt, DNS chuyển tên miền thành địa chỉ IP và chuyển yêu cầu đi tiếp để tìm tài nguyên. Việc chuyển tên miền thành địa chỉ IP được thực hiện bằng A record. Kẻ tấn công thực hiện reverse DNS lookup trên dải IP để xác định bản ghi DNS PTR cho các địa chỉ IP đó.

Kẻ tấn công dùng nhiều công cụ như DNSRecon, Reverse Lookup, prdns, Reverse IP Domain Check và Reverse IP Lookup để thực hiện reverse DNS lookup trên mục tiêu. Khi thu được địa chỉ IP hoặc dải địa chỉ IP, chúng ta có thể dùng các công cụ này để lấy tên miền.

DNSRecon

Nguồn: https://github.com

Lệnh ví dụ:

```
dnsrecon -r 162.241.216.0-162.241.216.255
```

Trong lệnh trên, tùy chọn -r chỉ định dải địa chỉ IP từ đầu đến cuối cho brute-force reverse lookup.

Trang 108 (theo PDF gốc)

Hình 2.71: Ảnh chụp màn hình DNSRecon hiển thị thông tin reverse DNS lookup.

Reverse Lookup

Nguồn: https://mxtoolbox.com

Như trong ảnh chụp màn hình, công cụ Reverse Lookup thực hiện reverse IP lookup bằng cách lấy một địa chỉ IP và định vị bản ghi DNS PTR cho địa chỉ IP đó.

Trang 109 (theo PDF gốc)

Hình 2.72: Ảnh chụp màn hình công cụ Reverse Lookup.

Trang 110 (theo PDF gốc)

Mục tiêu 07: Sử dụng các kỹ thuật khác nhau cho Network và Email Footprinting

Reconnaissance chủ động

NETWORK VÀ EMAIL FOOTPRINTING

Bước tiếp theo sau khi truy xuất thông tin DNS là thu thập thông tin liên quan đến mạng và theo dõi giao tiếp email. Phần này mô tả phương pháp xác định network range, traceroute analysis và các công cụ traceroute. Nó cũng mô tả cách theo dõi giao tiếp email, cách thu thập thông tin từ email header và các công cụ email tracking.

Xác định Network Range

Để thực hiện network footprinting, cần thu thập thông tin cơ bản và quan trọng về tổ chức mục tiêu như địa chỉ tổ chức, ai làm việc ở đó và loại công việc họ làm. Câu trả lời cho các câu hỏi này cung cấp thông tin về cấu trúc helpdesk nội bộ của tổ chức mục tiêu.

Sau khi thu thập thông tin, kẻ tấn công có thể xác định network range của hệ thống mục tiêu. Thông tin chi tiết về dải IP và vị trí có thể truy xuất bằng cơ sở dữ liệu regional registry phù hợp. Kẻ tấn công cũng có thể xác định subnet mask của miền và trace route giữa hệ thống và hệ thống mục tiêu. Các công cụ như Traceroute và PathPing được sử dụng rộng rãi để xác định network range.

Việc lấy private IP address có thể hữu ích cho kẻ tấn công. Internet Assigned Numbers Authority (IANA) đã dành các khối địa chỉ IP sau cho private Internet:

10.0.0.0-10.255.255.255 (10/8 prefix)

172.16.0.0-172.31.255.255 (172.16/12 prefix)

192.168.0.0-192.168.255.255 (192.168/16 prefix)

Dùng network range, kẻ tấn công có thể có thông tin về cấu trúc mạng và máy đang trong mạng hoặc đang kết nối với mạng. Network range cũng giúp xác định topology mạng, thiết bị kiểm soát truy cập và OS dùng trong mạng mục tiêu. Để tìm network range của mạng mục tiêu, có thể nhập server IP address thu thập được từ Whois footprinting vào công cụ tìm kiếm ARIN Whois database.

Trang 111 (theo PDF gốc)

ARIN Whois Database Search Tool

Người dùng cũng có thể truy cập website ARIN (https://www.arin.net/about/welcome/region/) và nhập server IP vào trường SEARCH site hoặc Whois text box. Kết quả trả về network range của mục tiêu. DNS server cấu hình không đúng cung cấp cho kẻ tấn công danh sách máy nội bộ. Ngoài ra, nếu kẻ tấn công thực hiện route tracing, họ có thể tìm địa chỉ của gateway, đây là thông tin hữu ích.

Hình 2.73: Ảnh chụp màn hình ARIN's Region.

Trang 112 (theo PDF gốc)

Hình 2.74: Ảnh chụp màn hình kết quả tìm kiếm ARIN Whois database.

Kẻ tấn công thường dùng nhiều hơn một công cụ để thu thập thông tin mạng, vì một công cụ duy nhất không thể cung cấp tất cả thông tin cần thiết.

Trang 113 (theo PDF gốc)

TRACEROUTE

Tìm route của host mục tiêu trên mạng là cần thiết để kiểm thử các kiểu tấn công man-in-the-middle và các cuộc tấn công liên quan. Hầu hết hệ điều hành cung cấp tiện ích Traceroute để thực hiện tác vụ này. Nó theo dõi đường đi hoặc route mà các gói tin host mục tiêu đi qua trong mạng.

Traceroute dùng giao thức ICMP và Time to Live (TTL) để tìm đường đi mà host đi qua trong mạng.

Tiện ích Traceroute có thể mô tả đường đi mà gói IP di chuyển giữa hai hệ thống. Tiện ích có thể dò số router mà packet đi qua, thời gian round-trip giữa hai router và, nếu router có DNS entry, tên router và vị trí của nó. Nếu một router không nằm trên đường truy cập, thời gian round-trip của nó sẽ bằng 0. Trường TTL cho biết số router hoặc hop mà packet sẽ đi qua trước khi bị loại bỏ. Traceroute dùng TTL để xác định các router trung gian. Nó tăng count trong ICMP header lên một sau mỗi bước. Khi count về zero, router loại packet và gửi thông báo lỗi ICMP cho nguồn của packet.

Trang 114 (theo PDF gốc)

Hình 2.75: Minh họa Traceroute.

Tiện ích ghi lại địa chỉ IP và tên DNS của router rồi gửi một packet khác với TTL bằng 2. Packet này đi qua router đầu tiên rồi timeout tại router kế tiếp. Router thứ hai cũng gửi thông báo lỗi trở lại host ban đầu. Traceroute tiếp tục gửi request với TTL tăng dần cho đến khi packet cuối cùng đến đích và host trả lời hoặc bị loại bỏ. Trong quá trình này, nó ghi lại thời gian mỗi packet thực hiện một round trip tới từng router. Cuối cùng, khi packet đến đích, ICMP echo reply bình thường được gửi trở lại sender. Tiện ích giúp tiết lộ IP address của intermediate hop cũng như route đến target host từ source.

ICMP Traceroute

Theo mặc định, hệ điều hành Windows dùng ICMP traceroute. Mở command prompt và gõ lệnh tracert cùng địa chỉ IP hoặc tên miền đích:

C:\>tracert 216.239.36.10

Trang 115 (theo PDF gốc)

Hình 2.76: Ảnh chụp màn hình đầu ra tracert.

TCP Traceroute

Nhiều thiết bị trong mạng thường được cấu hình để chặn thông điệp ICMP traceroute. Trong trường hợp này, kẻ tấn công dùng TCP hoặc UDP traceroute, còn được gọi là Layer 4 traceroute. Trên Linux, vào terminal và gõ lệnh tcptraceroute cùng địa chỉ IP hoặc domain name đích:

```
sudo tcptraceroute www.google.com
```

Hình 2.77: Ảnh chụp màn hình đầu ra TCP Traceroute.

UDP Traceroute

Giống Windows, Linux cũng có tiện ích traceroute tích hợp nhưng dùng giao thức UDP để tracing route tới đích. Trên Linux, gõ lệnh traceroute cùng địa chỉ IP hoặc domain name đích:

```
traceroute www.google.com
```

Trang 116 (theo PDF gốc)

Hình 2.78: Ảnh chụp màn hình đầu ra UDP Traceroute.

Trang 117 (theo PDF gốc)

TRACEROUTE VỚI AI

Kẻ tấn công có thể tận dụng công nghệ hỗ trợ AI để nâng cao và tự động hóa hoạt động footprinting. Với sự trợ giúp của AI, kẻ tấn công có thể dễ dàng thực hiện tracerouting trên mục tiêu.

Ví dụ, kẻ tấn công có thể dùng ChatGPT để thực hiện tác vụ bằng prompt phù hợp:

“Perform network tracerouting to discover the routers on the path to a target host www.certifiedhacker.com”

(Thực hiện tracerouting mạng để phát hiện các router trên đường đến host mục tiêu www.certifiedhacker.com.)

Trang 118 (theo PDF gốc)

Hình 2.79: Prompt và đầu ra thực hiện Traceroute với AI.

Lệnh shell sau được thiết kế để thực hiện network tracerouting bằng công cụ “traceroute” nhằm phát hiện các router trên đường tới host www.certifiedhacker.com:

```
traceroute www.certifiedhacker.com
```

Giải thích:

- traceroute www.certifiedhacker.com: khởi chạy công cụ traceroute để phát hiện các router trên đường tới host www.certifiedhacker.com bằng cách gửi packet đến đích với giá trị TTL tăng dần và phân tích phản hồi nhận được từ intermediate router.

Trang 119 (theo PDF gốc)

PHÂN TÍCH TRACEROUTE

Chúng ta đã thảo luận cách tiện ích traceroute giúp tìm địa chỉ IP của intermediate device như router và firewall hiện diện giữa source và destination. Sau khi chạy một số traceroute, kẻ tấn công có thể tìm vị trí hoặc hop trong mạng mục tiêu. Ví dụ kết quả traceroute:

- traceroute 1.10.10.20, second to last hop là 1.10.10.1
- traceroute 1.10.20.10, third to last hop là 1.10.10.1
- traceroute 1.10.20.10, second to last hop là 1.10.10.50
- traceroute 1.10.20.15, third to last hop là 1.10.10.1
- traceroute 1.10.20.15, second to last hop là 1.10.10.50

Bằng cách phân tích các kết quả này, kẻ tấn công có thể xác định intermediate device hoặc host trên đường tới mạng mục tiêu, như minh họa trong hình.

Hình 2.80: Phân tích Traceroute.

Trang 120 (theo PDF gốc)

CÔNG CỤ TRACEROUTE

Các công cụ Traceroute như NetScanTools Pro, PingPlotter, Traceroute NG và tracert hữu ích để trích xuất thông tin như vị trí địa lý của router, server và IP device trong mạng. Các công cụ này giúp trace, xác định và giám sát hoạt động mạng trên một số router của thiết bị nguồn và đích.

Chức năng có thể gồm:

- Hop-by-hop traceroute.
- Reverse tracing.
- Historical analysis.
- Packet loss reporting.
- Reverse DNS.
- Ping plotting.
- Port probing.
- Phát hiện vấn đề mạng.
- Phân tích chỉ số hiệu suất.
- Giám sát hiệu suất mạng.

NetScanTools Pro

Nguồn: https://www.netscantools.com

Kẻ tấn công có thể dùng NetScanTools Pro để trace route mà packet đi qua từ máy của họ đến thiết bị mục tiêu trong mạng cục bộ hoặc qua Internet. Công cụ cung cấp ICMP, UDP hoặc TCP traceroute và cho phép tìm các intermediate device dọc theo route. Nó cũng giúp xác định quốc gia được gán cho mỗi địa chỉ IPv4 trong từng hop.

Hình 2.81: Ảnh chụp màn hình NetScanTools Pro.

Trang 121 (theo PDF gốc)

PingPlotter

Nguồn: https://www.pingplotter.com

PingPlotter cho phép kẻ tấn công thu thập dữ liệu traceroute cho các host mục tiêu bằng ICMP, UDP và TCP packet. Nó tự động phát hiện network hop và theo dõi độ trễ cũng như packet loss theo thời gian. Bằng công cụ này, kẻ tấn công có thể trực quan hóa dữ liệu traceroute ở dạng dễ đọc. Công cụ hỗ trợ xác định bottleneck băng thông, nhiễu Wi-Fi hoặc lỗi phần cứng trong mạng mục tiêu.

Hình 2.82: Ảnh chụp màn hình PingPlotter.

Trang 122 (theo PDF gốc)

THEO DÕI GIAO TIẾP EMAIL

Email tracking giám sát email của một người dùng cụ thể. Loại tracking này có thể thực hiện thông qua digitally time-stamped records tiết lộ thời gian và ngày khi mục tiêu nhận và mở một email cụ thể. Công cụ email tracking cho phép kẻ tấn công thu thập thông tin như IP address, mail server và service provider liên quan đến người nhận email. Kẻ tấn công có thể dùng thông tin này để xây dựng profile của tổ chức mục tiêu và thực hiện các cuộc tấn công tiếp theo. Ví dụ công cụ email tracking gồm IP2LOCATION's Email Header Tracer, MxToolbox, DNS Checker Email Header Analyzer và Social Catfish.

Thông tin thu được bằng công cụ email tracking gồm:

- Địa chỉ IP hệ thống của người nhận: cho phép theo dõi địa chỉ IP của người nhận.
- Vị trí địa lý: ước tính và hiển thị vị trí người nhận trên bản đồ và có thể tiết lộ ngày/giờ hoặc thông tin khác liên quan.
- Email đã nhận và đã đọc: thông báo khi email được người nhận nhận và đọc.
- Thời lượng đọc: thời gian người nhận đọc email do người gửi gửi.
- Phát hiện proxy: cung cấp thông tin về loại server người nhận sử dụng.
- Links: kiểm tra các liên kết gửi cho người nhận xem đã được kiểm tra/nhấp hay chưa.
- Thông tin hệ điều hành và trình duyệt: tiết lộ OS và trình duyệt web của người nhận. Kẻ tấn công có thể dùng thông tin này để tìm lỗ hổng trong hệ điều hành và trình duyệt nhằm phát động thêm tấn công.

Trang 123 (theo PDF gốc)

- Forward Email: Xác định liệu email gửi tới người dùng có được chuyển tiếp cho người khác hay không.
- Device Type: Cung cấp thông tin về loại thiết bị dùng để mở và đọc email, ví dụ máy tính để bàn, thiết bị di động hoặc laptop.
- Path Traveled: Theo dõi đường đi mà email đã đi qua các mail transfer agent từ nguồn đến hệ thống đích.

Thu thập thông tin từ Email Header

Email header chứa các chi tiết về sender, routing information, addressing scheme, date, subject và recipient. Email header cũng giúp kẻ tấn công truy vết đường định tuyến mà email đi qua từ sender đến recipient. Email header là một nguồn thông tin hữu ích cho kẻ tấn công nhằm thực hiện tấn công vào mục tiêu. Quá trình xem email header khác nhau tùy chương trình email.

Các chương trình email phổ biến:

- eM Client
- Mailbird
- Hiri
- Mozilla Thunderbird
- Spike
- Claws Mail
- SmarterMail Webmail
- Outlook
- Apple Mail
- ProtonMail
- AOL Mail
- Tuta

Email header chứa các thông tin:

- Mail server của sender.
- Ngày và giờ email được mail server của người gửi nhận.
- Authentication system dùng bởi mail server của sender.
- Ngày và giờ gửi message.
- Một số duy nhất do mx.google.com gán để định danh message.
- Họ tên đầy đủ của sender.
- Địa chỉ IP và địa chỉ của sender từ nơi message được gửi.

Kẻ tấn công có thể trace và thu thập tất cả thông tin này bằng phân tích chi tiết email header hoàn chỉnh.

Trang 124 (theo PDF gốc)

Hình 2.83: Ảnh chụp màn hình phân tích chi tiết email header, minh họa địa chỉ gửi thư, sender IP, sender mail server, authentication system, thời gian gửi/nhận và tên đầy đủ của sender.

Công cụ Email Tracking

Các công cụ email tracking như IP2LOCATION's Email Header Tracer, MxToolbox, eMailTrackerPro, Holehe, DNS Checker Email Header Analyzer và Social Catfish cho phép kẻ tấn công theo dõi email và trích xuất thông tin như danh tính sender, mail server, sender IP address, vị trí, v.v. Kẻ tấn công dùng thông tin trích xuất để theo dõi đường email và từ địa chỉ IP xác định mail server mục tiêu bằng email header.

eMailTrackerPro

Nguồn: https://www.emailtrackerpro.com

Như trong ảnh chụp màn hình, kẻ tấn công dùng eMailTrackerPro để phân tích email header và trích xuất thông tin như địa chỉ email sender, geographical location, IP address, v.v. Nó cho phép kẻ tấn công xem lại trace sau bằng cách lưu trace trước đó.

Trang 125 (theo PDF gốc)

Hình 2.84: Ảnh chụp màn hình eMailTrackerPro.

IP2LOCATION's Email Header Tracer

Nguồn: https://www.ip2location.com

IP2LOCATION's Email Header Tracer là dịch vụ mã nguồn mở mà kẻ tấn công có thể dùng để phân tích và trace email path bằng email header. Nó cho phép kẻ tấn công theo dõi lại vị trí mục tiêu và mail server mà email đi qua, sử dụng địa chỉ IP tìm được trong email header.

Trang 126 (theo PDF gốc)

Hình 2.85: Ảnh chụp màn hình IP2LOCATION's Email Header Tracer.

Hình 2.86: Ảnh chụp màn hình IP2LOCATION's Email Header Tracer với kết quả chi tiết geolocation/ISP và thông tin liên quan.

Trang 127 (theo PDF gốc)

Mục tiêu 08: Minh họa Footprinting thông qua Social Engineering

Reconnaissance chủ động

FOOTPRINTING THÔNG QUA SOCIAL ENGINEERING

Cho đến đây, chúng ta đã thảo luận các kỹ thuật thu thập thông tin bằng tài nguyên hoặc công cụ. Bây giờ sẽ thảo luận footprinting thông qua social engineering, tức nghệ thuật lấy thông tin từ con người bằng cách khai thác điểm yếu của con người. Phần này, trừ khi khái niệm social engineering được trình bày ở một mô-đun khác, giới thiệu footprinting thông qua social engineering.

Nội dung trên slide nêu:

- Social engineering là nghệ thuật khai thác hành vi con người để lấy thông tin bí mật.
- Social engineers phụ thuộc vào thực tế rằng con người không nhận thức được thông tin có giá trị và bất cẩn trong việc bảo vệ nó.

Social engineers cố thu thập:

- Credit card details và social security number.
- Usernames và passwords.
- Security products đang dùng.
- Operating system và software version.
- Network layout information.
- IP addresses và tên server.

Các kỹ thuật social engineering gồm:

- Eavesdropping.
- Shoulder surfing.
- Dumpster diving.
- Impersonation.

Trang 128 (theo PDF gốc)

Social engineering là quá trình phi kỹ thuật trong đó kẻ tấn công đánh lừa một người cung cấp thông tin bí mật một cách vô ý. Nói cách khác, mục tiêu không nhận thức rằng ai đó đang đánh cắp thông tin bí mật. Kẻ tấn công tận dụng bản chất dễ tin của con người và sự sẵn sàng cung cấp thông tin bí mật.

Để thực hiện social engineering, kẻ tấn công trước tiên cần có được sự tin cậy của người dùng được ủy quyền rồi đánh lừa người đó tiết lộ thông tin bí mật. Mục tiêu của social engineering là lấy thông tin bí mật cần thiết và dùng thông tin đó cho mục đích độc hại như giành quyền truy cập trái phép vào hệ thống, đánh cắp danh tính, industrial espionage, network intrusion, fraud, v.v. Thông tin thu được qua social engineering có thể gồm thông tin thẻ tín dụng, social security number, username và password, thông tin cá nhân, sản phẩm bảo mật đang dùng, hệ điều hành và phiên bản phần mềm, địa chỉ IP và tên server, network layout information, v.v.

Social engineering có thể được thực hiện bằng nhiều cách như eavesdropping, shoulder surfing, dumpster diving, impersonation, tailgating, third-party authorization, piggybacking, reverse social engineering, v.v.

Trang 129 (theo PDF gốc)

THU THẬP THÔNG TIN QUA SOCIAL ENGINEERING TRÊN SOCIAL NETWORKING SITES

Social networking site là dịch vụ trực tuyến, nền tảng hoặc site cho phép mọi người kết nối và xây dựng quan hệ cá nhân. Việc sử dụng social networking site ngày càng tăng nhanh. Ví dụ site gồm LinkedIn, Facebook, Instagram, Twitter, Pinterest, YouTube, v.v. Mỗi site có tính năng hoặc mục đích riêng. Trên social networking site, người ta có thể đăng, cập nhật và sửa hồ sơ theo yêu cầu. Social networking site mở cho tất cả. Kẻ tấn công có thể tận dụng điều này để thu thập thông tin nhạy cảm từ người dùng bằng cách duyệt hồ sơ công khai hoặc tạo hồ sơ giả để đóng vai người dùng thật. Trên social networking site, người ta có thể đăng thông tin cá nhân như ngày sinh, trình độ học vấn, tình trạng việc làm, tên người thân, v.v. Các tổ chức thường đăng thông tin như đối tác tiềm năng, website và tin tức sắp tới về công ty.

Đối với kẻ tấn công, social networking site có thể là nguồn thông tin có giá trị về người hoặc tổ chức mục tiêu. Kẻ tấn công chỉ có thể thu thập thông tin do cá nhân đăng. Không có rào cản để kẻ tấn công truy cập public page của account tạo trên social networking site. Để thu thập thêm thông tin về mục tiêu, kẻ tấn công có thể tạo tài khoản giả và dùng social engineering technique để dụ nạn nhân tiết lộ thêm thông tin. Ví dụ, kẻ tấn công có thể gửi friend request cho người mục tiêu từ tài khoản giả; nếu nạn nhân chấp nhận yêu cầu, kẻ tấn công có thể truy cập cả thông tin hạn chế của người mục tiêu trên website.

Thông tin có sẵn trên Social Networking Sites

Cho đến đây, chúng ta đã thảo luận cách kẻ tấn công có thể thu thập thông tin từ social networking site. Sau đây là loại thông tin có thể lấy từ các site này.

Trang 130 (theo PDF gốc)

Người dùng thường duy trì hồ sơ trên social networking site để cung cấp thông tin cơ bản về bản thân và giúp tạo, duy trì kết nối với người khác. Hồ sơ thường chứa thông tin cá nhân như tên, thông tin liên hệ (số điện thoại di động, email, địa chỉ), thông tin bạn bè/gia đình, sở thích và hoạt động. Mọi người thường cập nhật bạn bè và người khác về họ. Kẻ tấn công có thể thu thập thông tin thông qua các cuộc trò chuyện này. Social networking site cũng cho phép chia sẻ ảnh và video. Người dùng không đặt cài đặt quyền riêng tư phù hợp cho album ảnh, sau đó kẻ tấn công có thể thấy ảnh và video được bạn bè gửi. Người dùng có thể tham gia group để chơi game hoặc chia sẻ sở thích. Kẻ tấn công có thể thu thập thông tin về sở thích nạn nhân bằng cách theo dõi các game/group của họ rồi đánh lừa nạn nhân tiết lộ thêm thông tin. Người dùng có thể tạo event để thông báo dịp sắp tới, từ đó kẻ tấn công biết lịch trình vắng mặt của người dùng.

Bảng 2.5 - Hoạt động của người dùng trên social networking site và thông tin kẻ tấn công có thể thu thập:

- Duy trì hồ sơ -> thông tin liên hệ, vị trí và thông tin liên quan.
- Kết nối với bạn bè -> danh sách bạn bè, thông tin bạn bè và thông tin liên quan.
- Chia sẻ ảnh và video -> danh tính thành viên gia đình, sở thích và thông tin liên quan.
- Chơi game, tham gia group -> sở thích.
- Tạo sự kiện -> hoạt động.

Giống cá nhân, tổ chức cũng dùng social networking site để kết nối với người khác, quảng bá sản phẩm và thu thập phản hồi về sản phẩm và dịch vụ. Hoạt động của tổ chức trên social networking site và thông tin tương ứng mà kẻ tấn công có thể thu thập:

- User surveys -> chiến lược kinh doanh.
- Promote products -> hồ sơ sản phẩm.
- User support -> social engineering.
- Recruitment -> thông tin nền tảng/công nghệ.
- Background check to hire employees -> loại hình doanh nghiệp.

Trang 131 (theo PDF gốc)

THU THẬP THÔNG TIN BẰNG EAVESDROPPING, SHOULDER SURFING, DUMPSTER DIVING VÀ IMPERSONATION

Eavesdropping, shoulder surfing, dumpster diving và impersonation là các kỹ thuật social engineering được dùng rộng rãi để thu thập thông tin từ con người.

Eavesdropping

Eavesdropping là hành vi chặn bắt giao tiếp dưới bất kỳ hình thức nào như audio, video hoặc text mà không có sự đồng ý của các bên giao tiếp. Nó cũng bao gồm đọc các message bí mật từ phương tiện truyền thông như instant messaging hoặc fax. Kẻ tấn công có thể thu thập thông tin từ mục tiêu bằng phone conversation hoặc chặn audio, video hoặc communication bằng văn bản.

Shoulder Surfing

Shoulder surfing là kỹ thuật trong đó kẻ tấn công bí mật quan sát mục tiêu để lấy thông tin quan trọng. Trong shoulder surfing, kẻ tấn công đứng sau nạn nhân và bí mật quan sát hoạt động của nạn nhân trên máy tính, như keystroke khi nhập username, password, số thẻ tín dụng, security code, account number, credit card information và dữ liệu tương tự. Kẻ tấn công có thể dễ dàng thực hiện shoulder surfing ở nơi đông người vì tương đối dễ đứng sau và quan sát nạn nhân mà họ không biết.

Dumpster Diving

Kỹ thuật này, còn gọi là trashing, liên quan đến việc kẻ tấn công lục thùng rác để tìm thông tin. Kẻ tấn công có thể thu được thông tin quan trọng như hóa đơn điện thoại, thông tin liên hệ, thông tin tài chính, thông tin liên quan hoạt động, bản in source code, bản in thông tin nhạy cảm, v.v. từ thùng rác của công ty mục tiêu, thùng rác máy in, sticky note trên bàn người dùng, v.v. Kẻ tấn công cũng có thể thu thập thông tin tài khoản từ thùng rác ATM. Thông tin có thể giúp kẻ tấn công thực hiện tấn công.

Trang 132 (theo PDF gốc)

Impersonation

Impersonation là kỹ thuật trong đó kẻ tấn công giả vờ là người hợp pháp hoặc được ủy quyền. Kẻ tấn công thực hiện impersonation attack trực tiếp hoặc qua điện thoại hay phương tiện liên lạc khác nhằm đánh lừa mục tiêu tiết lộ thông tin. Kẻ tấn công có thể giả làm người giao hàng, nhân viên vệ sinh, doanh nhân, khách hàng, kỹ thuật viên hoặc có thể giả làm khách. Dùng kỹ thuật này, kẻ tấn công thu thập thông tin bằng cách quét sơ bộ các tài liệu quan trọng trên bàn, lục thùng rác, v.v. Kẻ tấn công thậm chí có thể cố nghe lén các cuộc trò chuyện bí mật và “shoulder surf” để lấy thông tin nhạy cảm.

Trang 133 (theo PDF gốc)

Mục tiêu 09: Tự động hóa tác vụ Footprinting bằng công cụ nâng cao và AI

Reconnaissance chủ động

CÔNG CỤ FOOTPRINTING: MALTEGO VÀ RECON-NG

Maltego có thể được dùng để xác định mối quan hệ và liên kết thế giới thực giữa people, groups, organizations, websites, Internet infrastructure, documents, v.v.

Recon-ng là Web Reconnaissance framework với các module độc lập và tương tác, hỗ trợ database và cung cấp môi trường chung để thực hiện web-based reconnaissance.

Trang 134 (theo PDF gốc)

CÔNG CỤ FOOTPRINTING: FOCA VÀ subfinder

FOCA (Fingerprinting Organizations with Collected Archives) là công cụ dùng chủ yếu để tìm metadata và thông tin ẩn trong tài liệu.

subfinder là công cụ khám phá subdomain giúp kẻ tấn công tìm subdomain hợp lệ cho website bằng passive online source. Nó hỗ trợ nhiều định dạng đầu ra như JSON, file, stdout.

CÔNG CỤ FOOTPRINTING: OSINT FRAMEWORK

OSINT Framework là open-source intelligence gathering framework giúp chuyên gia bảo mật tìm các công cụ footprinting và reconnaissance cũng như intelligence gathering miễn phí.

Nó bao gồm cấu trúc cây đơn giản với nhiều danh mục và thư mục con; mỗi nhánh chứa các công cụ phục vụ mục đích cụ thể.

Một số công cụ khác hiển thị trên slide: Sudomy, BillCipher, whatweb, Raccoon, Recon-Dog, Web Check, OSINT.SH.

TỰ ĐỘNG HÓA TÁC VỤ FOOTPRINTING BẰNG CÔNG CỤ NÂNG CAO VÀ AI

Nhiều tổ chức cung cấp các công cụ hỗ trợ thu thập thông tin. Phần này mô tả các công cụ dùng để lấy thông tin từ nhiều nguồn.

Các công cụ footprinting được dùng để thu thập thông tin cơ bản về hệ thống mục tiêu nhằm khai thác. Thông tin thu thập bởi công cụ footprinting gồm địa chỉ IP của mục tiêu, thông tin định tuyến, thông tin doanh nghiệp, địa chỉ, số điện thoại, social security number, chi tiết về nguồn email và tệp, thông tin DNS và thông tin miền.

Trang 135 (theo PDF gốc)

Maltego

Nguồn: https://www.maltego.com

Maltego là công cụ tự động dùng để xác định mối quan hệ và liên kết thế giới thực giữa people, groups of people, organizations, websites, Internet infrastructure, documents, v.v.

Kẻ tấn công có thể dùng nhiều entity trong công cụ để thu thập thông tin như địa chỉ email, danh sách số điện thoại và hạ tầng Internet của mục tiêu (domain, DNS name, Netblocks, IP address information).

Như trong ảnh chụp màn hình, kẻ tấn công thêm Website entity, đổi tên bằng miền mục tiêu và lấy địa chỉ email cũng như số điện thoại liên quan đến mục tiêu.

Hình 2.87: Ảnh chụp màn hình Maltego.

Recon-ng

Nguồn: https://github.com

Recon-ng là web reconnaissance framework với các module độc lập cho database interaction, cung cấp môi trường để thực hiện open-source web-based reconnaissance.

Trang 136 (theo PDF gốc)

Như trong ảnh chụp màn hình, kẻ tấn công dùng module recon/domains-hosts/brute_hosts để trích xuất danh sách host liên quan tới URL mục tiêu.

Hình 2.88: Ảnh chụp màn hình recon-ng.

FOCA

Nguồn: https://www.elevenpaths.com

FOCA (Fingerprinting Organizations with Collected Archives) là công cụ dùng chủ yếu để tìm metadata và thông tin ẩn trong tài liệu mà nó quét. FOCA có khả năng quét và phân tích nhiều loại tài liệu, phổ biến nhất là Microsoft Office, Open Office hoặc PDF.

Các tính năng:

- Web Search: tìm host và domain name qua URL liên quan tới main domain. Mỗi link được phân tích để trích xuất thông tin từ host và domain name mới.
- DNS Search: kiểm tra từng domain để xác định host name được cấu hình trong NS, MX và SPF server nhằm phát hiện host mới và domain alias.
- IP Resolution: phân giải từng host name bằng DNS để lấy IP address liên quan tới server. Để thực hiện chính xác, công cụ thực hiện phân tích nội bộ với DNS của tổ chức.
- PTR Scanning: tìm thêm server trong cùng segment của IP đã xác định; FOCA thực hiện PTR log scan.

Trang 137 (theo PDF gốc)

- Bing IP: Khởi chạy FOCA, là quá trình tìm kiếm các domain name mới liên quan tới địa chỉ IP của từng IP address được phát hiện.
- Common Names: Thực hiện dictionary attack lên DNS.

Như ảnh chụp màn hình, kẻ tấn công tìm miền mục tiêu và lấy thông tin tệp lưu trong đó. Các tệp trích xuất có thể xem trên web browser. Ngoài ra, kẻ tấn công có thể xem thêm thông tin như network domain, role, vulnerabilities và metadata của tổ chức mục tiêu.

Hình 2.89: Ảnh chụp màn hình FOCA.

subfinder

Nguồn: https://github.com

subfinder là công cụ khám phá subdomain giúp kẻ tấn công tìm subdomain hợp lệ cho website bằng passive online sources. Nó hỗ trợ nhiều định dạng đầu ra (JSON, file, stdout).

Trang 138 (theo PDF gốc)

Hình 2.90: Ảnh chụp màn hình subfinder, hiển thị các subdomain của mục tiêu.

OSINT Framework

Nguồn: https://osintframework.com

OSINT Framework là open-source intelligence gathering framework giúp chuyên gia bảo mật thực hiện automated footprinting và reconnaissance, OSINT research và intelligence gathering. Nó tập trung vào việc thu thập thông tin từ công cụ hoặc tài nguyên miễn phí. Framework bao gồm giao diện đơn giản hiển thị nhiều công cụ OSINT được sắp xếp theo danh mục, và được trình bày trên slide dưới dạng cây giao diện.

Các chỉ báo bên cạnh công cụ:

- (T): Cho biết liên kết tới công cụ phải được cài đặt và chạy cục bộ.
- (D): Google dork.
- (R): Yêu cầu đăng ký.
- (M): Cho biết URL chứa search term và chính URL phải được chỉnh sửa thủ công.

Trang 139 (theo PDF gốc)

Hình 2.91: Ảnh chụp màn hình OSINT Framework với cây danh mục/công cụ OSINT.

Recon-Dog

Nguồn: https://www.github.com

Recon-Dog là công cụ all-in-one cho mọi nhu cầu thu thập thông tin cơ bản. Nó dùng API để thu thập thông tin về hệ thống mục tiêu.

Các tính năng:

- Censys: dùng censys.io để thu thập lượng lớn thông tin về một địa chỉ IP.
- NS lookup: thực hiện name server lookup.
- Port scan: quét hầu hết cổng TCP phổ biến.
- Detect CMS: có thể phát hiện hơn 400 content management system.
- Whois lookup: thực hiện Whois lookup.
- Detect honeypot: dùng shodan.io để kiểm tra mục tiêu có phải honeypot không.

Trang 140 (theo PDF gốc)

Các tính năng khác của Recon-Dog:

- Find subdomains: dùng findsubdomains.com để tìm subdomain.
- Reverse IP lookup: thực hiện reverse IP lookup để tìm các domain liên quan đến một IP address.
- Detect technologies: dùng wappalyzer.com để phát hiện hơn 1000 công nghệ.
- All: chạy tất cả tiện ích đối với mục tiêu.

Hình 2.92: Ảnh chụp màn hình Recon-Dog.

BillCipher

Nguồn: https://www.github.com

BillCipher là công cụ thu thập thông tin cho website hoặc IP address. Nó có thể hoạt động trên mọi hệ điều hành hỗ trợ Python 2, Python 3 và Ruby. Công cụ bao gồm nhiều tùy chọn như DNS lookup, Whois lookup, port scanning, zone transfer, host finder và reverse IP lookup, giúp thu thập thông tin quan trọng.

Trang 141 (theo PDF gốc)

Hình 2.93: Ảnh chụp màn hình BillCipher.

Một số công cụ footprinting bổ sung:

- Sudomy (https://github.com)
- theHarvester (https://www.edge-security.com)
- whatweb (https://github.com)
- Raccoon (https://github.com)
- Orb (https://github.com)
- Web Check (https://web-check.xyz)
- OSINT.SH (https://osint.sh)

Trang 142 (theo PDF gốc)

CÁC CÔNG CỤ OSINT HỖ TRỢ AI

AI đã cách mạng hóa open-source intelligence (OSINT) bằng cách tăng cường đáng kể khả năng điều tra thông qua thu thập dữ liệu nâng cao, phân tích và dự đoán. AI tự động hóa xử lý dữ liệu, trích xuất insight liên quan và cung cấp intelligence có thể hành động hiệu quả hơn so với phương pháp truyền thống, đồng thời nâng cao các công cụ OSINT.

Các công cụ OSINT hỗ trợ AI có thể dùng AI để tăng cường và tự động hóa nhiều tác vụ OSINT khác nhau. Sau đây là một số use case chính:

- Web Scraping: Kỹ thuật AI dùng dữ liệu trực tuyến từ các nguồn như social media, blog, forum và online archive. AI nâng cao việc theo dõi thực thể theo thời gian hoặc giám sát hành vi công khai. Machine-learning model có thể tự động hóa việc trích xuất thông tin cụ thể như đề cập trên social media và reply.
- IP Geolocation: Machine learning (ML) có thể xác định entity trong dataset lớn và phân tích file để xác định quan hệ giữa các entity khác nhau. Những entity này gồm name, company detail, address, email, phone number và dữ liệu liên quan.
- Content Summarization: NLP algorithm có thể tóm tắt lượng lớn dữ liệu. Người thu thập OSINT có thể dùng khả năng này để trích xuất thông tin liên quan từ nhiều bài viết. Ví dụ, hệ thống AI có thể tóm tắt nội dung một bản trích xuất PDF dài thành vài trăm từ hoặc vài trang.
- Sentiment Analysis: Công nghệ AI có thể diễn giải cảm xúc con người thông qua phân tích văn bản, hữu ích đặc biệt để hiểu sentiment công chúng. Nhà nghiên cứu OSINT có thể dùng AI để đánh giá trạng thái cảm xúc của người dùng dựa trên bài đăng và bình luận mạng xã hội hoặc dự đoán hành vi người tiêu dùng dựa trên review.

Slide minh họa các công cụ như Taranis AI, OSS Insight và các công cụ khác: DorkGPT, DorkGenius, Google Word Sniper, Cylect.io, ChatPDF.

Trang 143 (theo PDF gốc)

- Image Recognition: Computer vision, một nhánh AI, có thể phân tích tệp media số như hình ảnh và video. Trong điều tra OSINT, computer vision có thể hỗ trợ:
- Face Recognition: nhận diện và theo dõi cá nhân trên các phương tiện khác nhau.
- Metadata Analysis: trích xuất metadata từ file kỹ thuật số.
- Reverse Image Search: tăng cường khả năng reverse image search và phát hiện hình ảnh deepfake.
- AI Detection: AI cũng có thể xác định nội dung được tạo bởi các công cụ AI khác, điều này rất quan trọng để phát hiện hoạt động độc hại được hỗ trợ bởi AI.

Lợi ích của việc tích hợp AI vào OSINT:

- Improved Efficiency: AI tăng hiệu quả OSINT bằng cách tự động hóa các tác vụ như web scraping và data extraction, giúp tăng tốc thu thập và phân tích dữ liệu. Điều này cho phép điều tra viên tập trung vào phân tích cấp cao và ra quyết định, đồng thời đẩy nhanh điều tra và cung cấp insight kịp thời.
- Greater Scope: AI mở rộng phạm vi OSINT bằng cách phân tích lượng dữ liệu khổng lồ từ surface web, deep web và dark web, đảm bảo bao phủ intelligence toàn diện. Khả năng xử lý dataset lớn và xác định kết nối giúp điều tra viên phát hiện mẫu ẩn và quan hệ khó tìm bằng thủ công.
- Enhanced Visibility: AI nâng cao khả năng hiển thị intelligence bằng cách kết nối hàng tỷ mẩu dữ liệu riêng lẻ thành thông tin kết nối, giúp điều tra viên nhanh chóng xác định hoạt động đáng ngờ và thiết lập liên kết giữa threat actor hoặc event. Công cụ AI cung cấp insight dưới dạng đồ họa thân thiện, giúp điều tra viên nhận biết và hiểu các quan hệ phức tạp và xu hướng trong dữ liệu dễ hơn.
- Increased Investigator Safety: AI tăng an toàn cho điều tra viên bằng cách hỗ trợ điều tra tự động. Điều này giảm nguy cơ làm lộ danh tính điều tra viên hoặc làm lộ thông tin nhạy cảm. Công cụ AI có thể tiến hành điều tra mà không cần điều tra viên tương tác trực tiếp trong môi trường online có khả năng nguy hiểm như dark web.

Công cụ OSINT hỗ trợ AI: Taranis AI

Nguồn: https://taranis.ai

Taranis AI là công cụ OSINT và situational analysis hỗ trợ AI. Nó dùng NLP và AI để cải thiện chất lượng dữ liệu nhận từ các nguồn dữ liệu như website nhằm thu thập intelligence phi cấu trúc. Analyst sau đó biến các bài viết được AI nâng cao thành draft report và có thể lưu vào thư mục trước khi cuối cùng được xuất bản.

Trang 144 (theo PDF gốc)

Các tính năng của Taranis AI:

- Advanced OSINT Capabilities: Taranis AI tìm kiếm nhiều nguồn dữ liệu, gồm website, để thu thập news article phi cấu trúc và cung cấp cái nhìn toàn diện, giàu dữ liệu về intelligence cần thiết.
- AI-Enhanced Analysis: Taranis AI tăng cường bài viết thu thập, đảm bảo chất lượng và tính liên quan cao hơn bằng AI và NLP.
- Multi-Format Output: Taranis AI tạo nhiều sản phẩm cuối khác nhau, gồm report có cấu trúc và file PDF, được điều chỉnh theo nhu cầu và yêu cầu thông tin cụ thể.
- Seamless Publishing: Nền tảng cho phép dễ dàng xuất bản sản phẩm intelligence hoàn chỉnh, bảo đảm phổ biến thông tin quan trọng hiệu quả.

Hình 2.94: Ảnh chụp màn hình Taranis AI.

Công cụ OSINT hỗ trợ AI: OSS Insight

Nguồn: https://ossinsight.io

OSS Insight tận dụng AI để đi sâu vào hệ sinh thái GitHub bằng cách phân tích dataset rộng lớn gồm hơn năm tỷ GitHub event. Khả năng này cho phép hiểu toàn diện xu hướng và hoạt động phát triển open-source hiện tại. Từ phân tích chi tiết repository giúp hiểu lý do cho sao/fork và commit đến hoạt động developer và collaboration pattern, OSS Insight được trang bị công cụ mạnh để khai thác dữ liệu, benchmarking và strategic planning trong phát triển phần mềm open-source.

Các tính năng chính của OSS Insight:

- GPT-Powered Data Exploration: cho phép người dùng truy vấn dữ liệu GitHub bằng ngôn ngữ tự nhiên, tạo SQL query và trình bày kết quả trực quan. Nó giúp hacker ethical thu thập intelligence về repository, hoạt động developer và trend mà không cần kiến thức SQL nâng cao, tăng hiệu quả điều tra.
- Technical Fields Analysis: nền tảng tạo bộ sưu tập GitHub trong technical domain và cung cấp phân tích ở các mảng như web framework, AI và Web3. Ethical hacker có thể dùng dữ liệu này để xác định emerging technology, potential vulnerability và landscape chuyên biệt theo industry.

Trang 145 (theo PDF gốc)

- Developer Analytics: Công cụ giám sát chỉ số năng suất developer như commit, pull request và code contribution, đồng thời là hành vi collaboration và engagement level. Ethical hacker có thể dùng dữ liệu này để đánh giá contributor activity và reliability, xác định điểm yếu tiềm năng trong security practice và tìm contributor rủi ro cao hoặc ít hoạt động.
- Repository Analytics: Công cụ đánh giá chỉ số GitHub repository như popularity (star và fork), update frequency và community engagement. Nó cung cấp trend lịch sử và comparative insight hỗ trợ benchmarking và strategic decision. Ethical hacker có thể phân tích health và security posture của repository, theo dõi cách issue và pull request được xử lý và xác định repository dễ bị tấn công do engagement thấp hoặc code lỗi thời.
- Compare Projects: Cho phép so sánh side-by-side các chỉ số từ nhiều GitHub project, gồm activity level, contributor demographic, issue-handling efficiency và technical metric. Điều này giúp ethical hacker xác định project có security practice tốt hơn, active community hoặc potential vulnerability để phục vụ strategic targeting và assessment.

Tầm quan trọng của OSS Insight trong OSINT cho Ethical Hacking

- Comprehensive Data Analysis: Bằng cách phân tích hơn năm tỷ GitHub event, OSS Insight cung cấp lượng dữ liệu lớn mà ethical hacker có thể dùng để thu thập intelligence về software vulnerability, popular framework và emerging trend. Dữ liệu này có thể hỗ trợ vulnerability assessment và xác định potential attack vector.
- Real-time and Historical Data: Tích hợp cập nhật real-time và historical data từ GitHub bảo đảm ethical hacker truy cập thông tin cập nhật về ongoing development và past incident trong GitHub ecosystem.
- AI-Powered Querying: GitHub Data Explorer hỗ trợ AI đơn giản hóa truy vấn dataset phức tạp bằng ngôn ngữ tự nhiên, giúp ethical hacker dễ trích xuất thông tin cụ thể hoặc insight liên quan đến điều tra.

Trang 146 (theo PDF gốc)

Hình 2.95: Ảnh chụp màn hình OSS Insight / GitHub Data Explorer.

Các công cụ OSINT hỗ trợ AI bổ sung

Công cụ OSINT hỗ trợ AI tận dụng AI để nâng cao hiệu quả và độ chính xác của việc thu thập open-source intelligence như sau:

DorkGPT

Nguồn: https://dorkgpt.com

DorkGPT là công cụ hỗ trợ AI được thiết kế để hỗ trợ Google Dorking, kỹ thuật dùng để tìm thông tin không dễ truy cập thông qua truy vấn tìm kiếm thông thường. Nó tận dụng khả năng AI của GPT Generative Pre-trained Transformer model để tạo và tinh chỉnh search query, giúp người dùng phát hiện thông tin nhạy cảm, hidden page và dữ liệu khác có thể liên quan đến cybersecurity, ethical hacking hoặc nghiên cứu.

DorkGenius

Nguồn: https://dorkgenius.com

DorkGenius là công cụ hỗ trợ AI tự động hóa Google Dorking và giúp người dùng tạo advanced search query để tìm thông tin cụ thể trên Internet. Nó hữu ích để phát hiện hidden file, directory, sensitive information và security vulnerability, đặc biệt trong ethical hacking.

Google Word Sniper

Nguồn: https://googlewordsniper.eu

Google Word Sniper giúp tinh chỉnh search query để có kết quả Google hiệu quả hơn. Nó xác định targeted keyword và phrase, giúp tìm thông tin cụ thể, hidden content và niche data. Công cụ có giá trị với researcher, marketer và cybersecurity professional vì tăng khả năng phát hiện thông tin có giá trị trong kết quả tìm kiếm.

Trang 147 (theo PDF gốc)

Cylect.io

Nguồn: https://cylect.io

Cylect.io là công cụ OSINT hỗ trợ AI tiên tiến tích hợp nhiều database vào giao diện thân thiện, cung cấp bộ resource lớn cho ethical hacker và hỗ trợ điều tra OSINT hiệu quả, nhất quán. Được phát triển để khắc phục tính kém hiệu quả của search engine truyền thống, Cylect.io đơn giản hóa quá trình tìm kiếm và tăng tốc cũng như độ chính xác của hoạt động thu thập dữ liệu trong điều tra.

ChatPDF

Nguồn: https://chatpdf.com

ChatPDF là công cụ OSINT tận dụng AI để phân tích và trích xuất thông tin từ tài liệu PDF qua giao diện hội thoại. Người dùng có thể upload PDF và tương tác với công cụ để nhanh chóng lấy dữ liệu cụ thể, summary và insight, trở thành tài nguyên giá trị cho ethical hacking.

Bardeen.ai

Nguồn: https://www.bardeen.ai

Bardeen.ai là công cụ tự động hóa có thể dùng cho OSINT bằng cách cho phép người dùng hợp lý hóa và tự động hóa quá trình thu thập và phân tích dữ liệu từ nhiều nguồn trực tuyến. Điều này nâng tốc độ và độ chính xác của điều tra OSINT, trở nên hữu ích cho cybersecurity professional, researcher và investigator.

DarkGPT

Nguồn: https://github.com/luijait/DarkGPT

DarkGPT là trợ lý AI dùng GPT-4-200K để truy vấn leaked database, hỗ trợ ethical hacker tìm kiếm efficient và targeted trong compromised data source. Điều này cho phép người dùng trích xuất thông tin quan trọng và insight, nâng cao khả năng OSINT cho cybersecurity analyst và researcher.

PenLink Cobwebs

Nguồn: https://cobwebs.com

PenLink Cobwebs là công cụ OSINT hỗ trợ AI tiên tiến chuyên thu thập và phân tích dữ liệu từ nhiều nguồn trực tuyến. Nó cung cấp khả năng toàn diện cho việc thu thập, xử lý và trực quan hóa thông tin nhằm hỗ trợ điều tra cybersecurity.

Explore AI

Nguồn: https://exploreai.vercel.app

Explore AI là công cụ tìm kiếm YouTube hỗ trợ AI dùng trí tuệ nhân tạo để tìm kiếm và trích xuất thông tin từ video YouTube, giúp dễ truy cập thông tin ẩn hoặc tăng cường.

Trang 148 (theo PDF gốc)

AnyPicker

Nguồn: https://app.anypicker.com

AnyPicker là web scraper mạnh và công cụ OSINT được thiết kế để trích xuất dữ liệu từ website mà không cần kỹ năng coding. Công cụ hỗ trợ scrape nhiều trang đồng thời và cung cấp preview theo thời gian thực về kết quả trích xuất, mang lại tính linh hoạt và hiệu quả trong thu thập dữ liệu web.

Trang 149 (theo PDF gốc)

TẠO VÀ CHẠY PYTHON SCRIPT TÙY CHỈNH ĐỂ TỰ ĐỘNG HÓA TÁC VỤ FOOTPRINTING VỚI AI

Kẻ tấn công có thể tận dụng công nghệ hỗ trợ AI để nâng cao và tự động hóa tác vụ footprinting. Với sự trợ giúp của AI, kẻ tấn công có thể dễ dàng tạo và chạy custom footprinting script và thu được insight có giá trị về mục tiêu. Bằng cách phát triển custom script hỗ trợ AI, kẻ tấn công có thể thực thi hiệu quả chuỗi lệnh footprinting website để thu thập dữ liệu từ một miền mục tiêu cho các mục đích cybersecurity assessment.

Ví dụ, kẻ tấn công có thể dùng ChatGPT để hướng dẫn phát triển script bằng prompt phù hợp như:

“Develop a Python script which will accept the domain name www.microsoft.com as input and execute a series of website footprinting commands, including DNS lookups, WHOIS records retrieval, email enumeration, and more, to gather information about the target domain.”

(Phát triển Python script nhận domain www.microsoft.com làm input và thực thi chuỗi lệnh website footprinting, gồm DNS lookup, truy xuất WHOIS record, email enumeration và các tác vụ khác để thu thập thông tin về miền mục tiêu.)

Trang 150 (theo PDF gốc)

Hình 2.96: Prompt và đầu ra khi thực hiện Traceroute với AI - Ảnh chụp 1.

Hình 2.97: Prompt và đầu ra khi thực hiện Traceroute với AI - Ảnh chụp 2.

Lệnh shell sau được thiết kế để thực hiện website footprinting gồm DNS lookup, WHOIS record retrieval, email enumeration và các tác vụ khác nhằm thu thập thông tin về miền mục tiêu www.microsoft.com:

```
cat <<'EOF' > website_footprinting.py
import subprocess


def dns_lookup(domain):
    return subprocess.getoutput(f"dig {domain} ANY +noall +answer")
```

Trang 151 (theo PDF gốc)

(Tiếp tục mã nguồn Python; mã được giữ nguyên để đảm bảo khả năng thực thi.)

```
def whois_lookup(domain):
    return subprocess.getoutput(f"whois {domain}")


def email_enumeration(domain):
    return subprocess.getoutput(f"theHarvester -d {domain} -b all -l 100")


def run_footprinting(domain):
    print("Performing DNS Lookup...")
    dns_info = dns_lookup(domain)
    print(dns_info)


    print("\nPerforming Whois Lookup...")
    whois_info = whois_lookup(domain)
    print(whois_info)


    print("\nEnumerating Emails...")
    emails = email_enumeration(domain)
    print(emails)


domain = 'www.microsoft.com'
run_footprinting(domain)
EOF
```

python3 website_footprinting.py

Giải thích:

Python script này định nghĩa bốn hàm: dns_lookup, whois_lookup, email_enumeration và run_footprinting.

- dns_lookup(domain): Thực hiện DNS lookup cho miền được chỉ định bằng lệnh dig.
- whois_lookup(domain): Truy xuất WHOIS record cho miền được chỉ định bằng lệnh whois.
- email_enumeration(domain): Enumerate email liên quan đến miền được chỉ định bằng công cụ theHarvester.
- run_footprinting(domain): Thực thi chuỗi lệnh website footprinting (DNS lookup, WHOIS lookup, email enumeration) cho miền đã cho và in kết quả.

Trang 152 (theo PDF gốc)

Bạn có thể chạy script bằng Python3 để thực hiện website footprinting trên miền được chỉ định (www.microsoft.com).

Các ảnh chụp màn hình minh họa:

- Hình 2.98: Đầu ra khi thực thi script với AI - Ảnh chụp 1, hiển thị quá trình “Performing DNS Lookup...” và kết quả DNS.
- Hình 2.99: Đầu ra khi thực thi script với AI - Ảnh chụp 2, hiển thị “Performing Whois Lookup...” và quá trình theHarvester.
- Hình 2.100: Đầu ra khi thực thi script với AI - Ảnh chụp 3, hiển thị các hostname/subdomain được thu thập.

Trang 153 (theo PDF gốc)

Hình 2.101: Đầu ra khi thực thi script với AI - Ảnh chụp 4, hiển thị danh sách các IP được tìm thấy.

Trang 154 (theo PDF gốc)

Mục tiêu 10: Giải thích các biện pháp đối phó Footprinting

BIỆN PHÁP ĐỐI PHÓ FOOTPRINTING

Các biện pháp chính được nêu trên slide:

- Hạn chế quyền truy cập của nhân viên vào các trang mạng xã hội trên mạng của tổ chức.
- Cấu hình web server để tránh rò rỉ thông tin.
- Giáo dục nhân viên sử dụng pseudonym trên blog, group và forum.
- Không tiết lộ thông tin quan trọng trong press release, annual report, product catalog, v.v.
- Giới hạn lượng thông tin công khai trên website.
- Sử dụng kỹ thuật footprinting để phát hiện và loại bỏ thông tin nhạy cảm bị công khai.
- Ngăn search engine caching một trang web và dùng dịch vụ đăng ký ẩn danh.

Trang 155 (theo PDF gốc)

BIỆN PHÁP ĐỐI PHÓ FOOTPRINTING (TIẾP)

Nội dung trên slide và phần giải thích tổng hợp các biện pháp:

- Phát triển và thực thi security policy như information security policy và password policy để điều chỉnh thông tin mà nhân viên có thể tiết lộ cho bên thứ ba.
- Triển khai multi-factor authentication để tăng cường bảo mật hệ thống và tài nguyên của tổ chức.
- Đặt split internal và external DNS hoặc sử dụng split DNS, đồng thời hạn chế zone transfer chỉ cho server được ủy quyền.
- Vô hiệu hóa hoặc hạn chế directory listing trên web server.
- Thực hiện security awareness training định kỳ để giáo dục nhân viên về nhiều social engineering trick và rủi ro.
- Chọn dịch vụ riêng tư trên Whois lookup database khi có thể.
- Tránh domain-level cross-linking cho các tài sản quan trọng.
- Mã hóa và bảo vệ dữ liệu nhạy cảm.
- Triển khai CAPTCHA và rate limiting trên public-facing service để ngăn các công cụ tự động thu thập thông tin nhanh.
- Không cho phép protocol transfer không cần thiết.
- Luôn dùng TCP/IP và IPSec filter cho defense in depth.
- Cấu hình Internet Information Services (IIS) để tránh tiết lộ thông tin qua banner grabbing.
- Ẩn địa chỉ IP và thông tin liên quan bằng VPN hoặc đặt server sau secure proxy.
- Yêu cầu archive.org xóa lịch sử website khỏi archive database nếu phù hợp.
- Giữ domain name profile riêng tư.
- Đặt critical document như business plan và proprietary document ở chế độ offline để tránh bị khai thác.
- Đào tạo nhân viên chống lại social engineering technique và attack.
- Làm sạch chi tiết dữ liệu cung cấp cho Internet registrar để ẩn thông tin liên hệ trực tiếp của tổ chức.
- Vô hiệu hóa geo-tagging trên camera để ngăn theo dõi vị trí địa lý.
- Tránh tiết lộ vị trí hoặc địa chỉ tổ chức trên social networking site khi không cần thiết.
- Tắt geolocation access trên thiết bị di động khi không cần.
- Bảo đảm không hiển thị thông tin quan trọng như strategic plan, product information hoặc sales projection trên notice board hoặc wall.
- Vô hiệu hóa hoặc xóa các nhân viên cũ/không còn làm việc khỏi website tổ chức.
- Cấu hình mail server để bỏ qua mail từ anonymous individual.
- Triển khai honeypot hoặc honeynet trong mạng để thu hút và phát hiện kẻ tấn công thực hiện footprinting từ bên ngoài hệ thống quan trọng.

Phần “Footprinting Countermeasures” giải thích rằng cho đến đây mô-đun đã thảo luận tầm quan trọng của footprinting, nhiều phương pháp thực hiện footprinting và các công cụ hỗ trợ thực thi. Tiếp theo, tài liệu trình bày một số biện pháp hoặc hành động để ngăn chặn hoặc hạn chế việc tiết lộ thông tin footprint.

Một số biện pháp đối phó tiêu biểu:

- Hạn chế quyền truy cập của nhân viên vào social networking site từ mạng tổ chức.
- Cấu hình web server để tránh rò rỉ thông tin.
- Giáo dục nhân viên dùng pseudonym trên blog, group và forum.
- Không tiết lộ thông tin quan trọng trong press release, annual report, product catalog, v.v.
- Hạn chế lượng thông tin công khai trên website hoặc Internet.
- Dùng kỹ thuật footprinting để tự phát hiện và loại bỏ thông tin nhạy cảm bị công khai.

- Ngăn search engine caching trang web và dùng dịch vụ đăng ký ẩn danh.
- Phát triển và thực thi security policy như information security và password policy nhằm kiểm soát thông tin nhân viên có thể tiết lộ cho bên thứ ba.
- Triển khai multi-factor authentication để tăng bảo mật hệ thống/tài nguyên.
- Dùng split DNS và hạn chế zone transfer cho server được ủy quyền.

Trang 156 (theo PDF gốc)

Các biện pháp đối phó tiếp theo:

- Vô hiệu hóa directory listing trên web server.
- Thực hiện security awareness training định kỳ để giáo dục nhân viên về social engineering trick và risk.
- Chọn dịch vụ Whois lookup có quyền riêng tư.
- Tránh domain-level cross-linking đối với critical asset.
- Mã hóa và bảo vệ dữ liệu nhạy cảm.
- Triển khai CAPTCHA và rate limiting trên public-facing service để ngăn công cụ tự động thu thập thông tin nhanh.
- Không bật protocol transfer không cần thiết.
- Luôn dùng TCP/IP và IPSec filter để defense in depth.
- Cấu hình IIS để tránh tiết lộ thông tin qua banner grabbing.
- Ẩn địa chỉ IP và thông tin liên quan bằng VPN hoặc giữ server sau secure proxy.
- Yêu cầu archive.org xóa lịch sử website khỏi archive database.
- Giữ domain name profile ở chế độ private.
- Đặt critical document như business plan và proprietary document offline để ngăn exploitation.
- Đào tạo nhân viên ngăn ngừa social engineering technique và attack.
- Làm sạch dữ liệu cung cấp cho Internet registrar để ẩn chi tiết liên hệ trực tiếp của tổ chức.
- Tắt geo-tagging trên camera nhằm ngăn theo dõi geolocation.
- Tránh tiết lộ location/address tổ chức trên social networking site.
- Tắt geolocation access trên mobile device khi không cần.
- Bảo đảm không để thông tin quan trọng như strategic plan, product information hoặc sales projection hiển thị trên notice board hoặc wall.
- Vô hiệu hóa hoặc xóa tài khoản/thông tin của nhân viên không còn làm việc khỏi website tổ chức.
- Cấu hình mail server để bỏ qua mail từ anonymous individual.
- Triển khai honeypot hoặc honeynet trong mạng để thu hút và phát hiện kẻ tấn công thực hiện footprinting tránh xa hệ thống quan trọng.

Trang 157 (theo PDF gốc)

TÓM TẮT MÔ-ĐUN

Mô-đun này trình bày các khái niệm footprinting cùng các mục tiêu của footprinting. Nó cung cấp giải thích chi tiết về nhiều kỹ thuật khác nhau dùng cho footprinting thông qua công cụ tìm kiếm. Ngoài ra, mô-đun mô tả footprinting thông qua Internet research service và social networking site. Nó cũng giải thích Whois và DNS footprinting chi tiết. Hơn nữa, nó mô tả network footprinting cùng với traceroute analysis. Bên cạnh đó, mô-đun thảo luận email footprinting, social engineering footprinting và footprinting bằng advanced tool và AI. Cuối cùng, nó trình bày tổng quan về các công cụ footprinting. Mô-đun kết thúc bằng mô tả chi tiết về cách tổ chức có thể tự bảo vệ trước các hoạt động footprinting và reconnaissance.

Trong mô-đun tiếp theo, chúng ta sẽ thảo luận chi tiết cách kẻ tấn công cũng như ethical hacker và penetration tester thực hiện network scanning để thu thập thông tin về mục tiêu hoặc đánh giá một cuộc tấn công hay kiểm toán.

Nội dung tóm tắt trên slide:

- Trong mô-đun này, chúng ta đã thảo luận định nghĩa về footprinting.
- Footprinting qua công cụ tìm kiếm và mục tiêu của footprinting.
- Nhiều kỹ thuật footprinting khác nhau như thu thập thông tin qua search engine, Internet research service, social networking site, Whois, DNS, email và network footprinting.
- Network footprinting và tracerouting thông qua social engineering.
- Một số công cụ footprinting.
- Các biện pháp mà tổ chức có thể áp dụng để bảo vệ khỏi footprinting và reconnaissance.
- Trong mô-đun tiếp theo, sẽ thảo luận cách hacker ethical và penetration tester thực hiện network scanning để thu thập thông tin về target hoặc đánh giá attack/audit.

Trang 158 (theo PDF gốc)

Trang này được cố ý để trống.